TÌM HIỂU VỀ GOPHISH

Mục lục

I. Gophish là gì ? 1

II. Phising Simulation là gì ? 2

III. Cài đặt và cấu hình cơ bản 2

IV. Các thành phần chính của Gophish 8

1. Dashboard 8
2. Campaign 8
3. Users & Groups 8
4. Email Templates 9
5. Landing Pages 9
6. Sending Profiles 9
7. Account Settings 10
8. User Management 10
9. Webhooks 11

V. Demo 11

VI. Đánh giá 24

VII. Đánh giá hiệu năng 24

1. Môi trường thử nghiệm 24
2. Cài đặt Locust 24
3. Lấy RID 25
4. Cấu hình file locust 25
5. Thực hiện kiểm thử 25

I. Gophish là gì ?

Gophish là một nền tảng mã nguồn mở được phát triển nhằm mục đích mô phỏng các chiến dịch phishing trong môi trường kiểm soát. Công cụ này được sử dụng chủ yếu trong đào tạo nhận thức an toàn thông tin và đánh giá rủi ro yếu tố con người trong tổ chức.

II. Phising Simulation là gì ?

Phishing simulation là quá trình mô phỏng các email lừa đảo nhằm kiểm tra khả năng nhận diện của người dùng. Mục tiêu không phải để đánh cắp dữ liệu mà để đo lường hành vi và cải thiện nhận thức

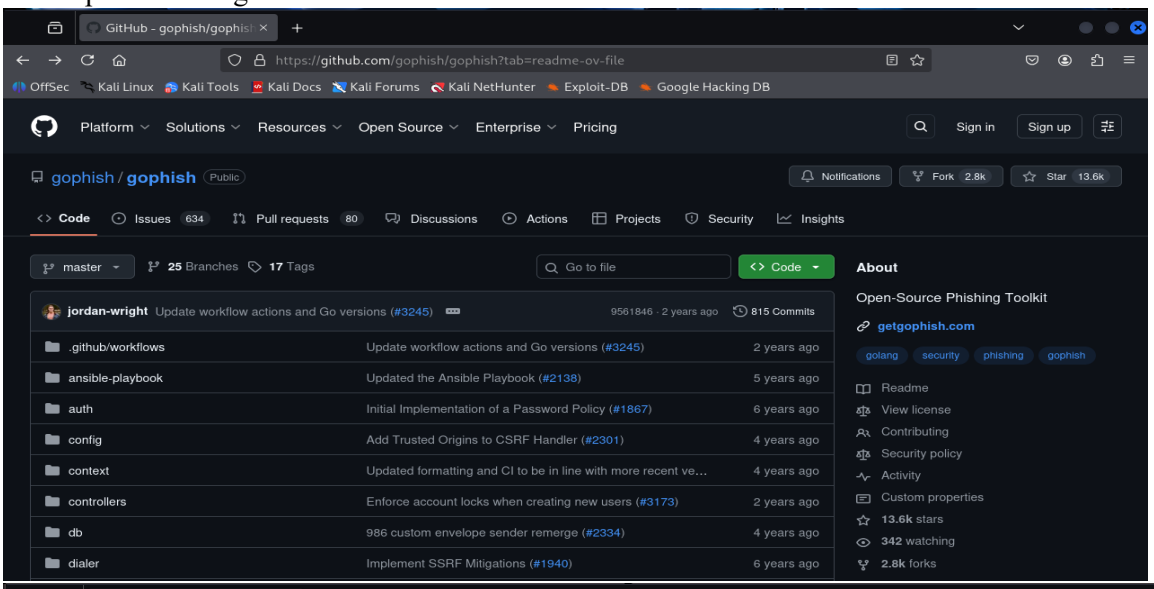
III. Cài đặt và cấu hình cơ bản

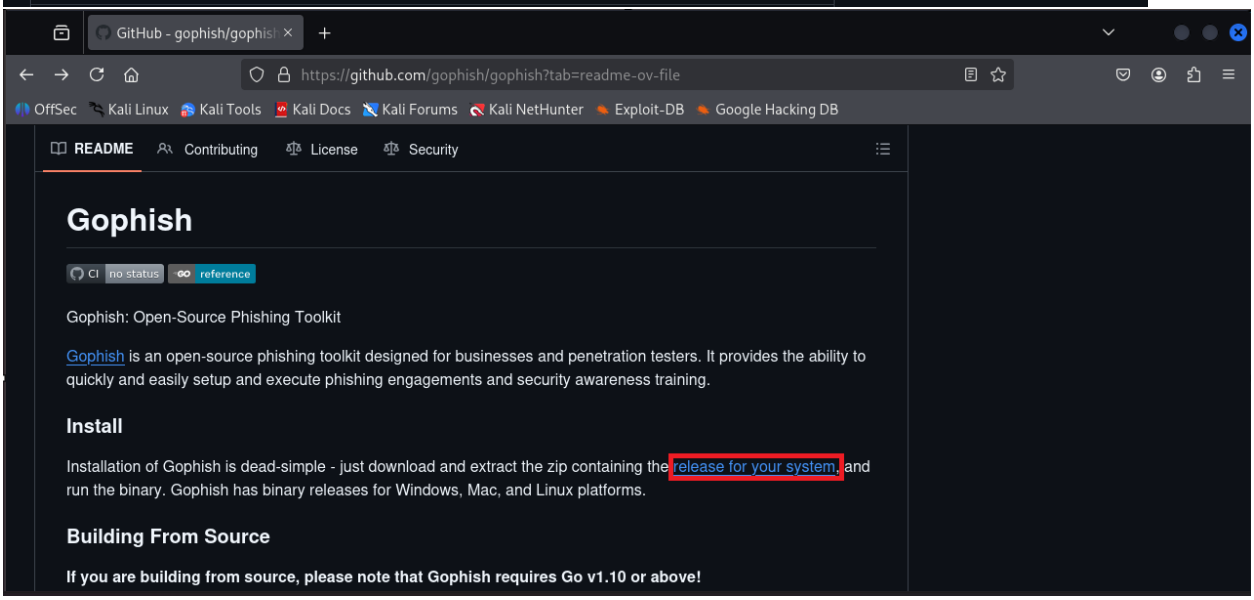
Yêu cầu hệ thống tối thiểu:

- CPU: 2 core
- RAM: 2GB
- Hệ điều hành: Windows/Linux/macOS

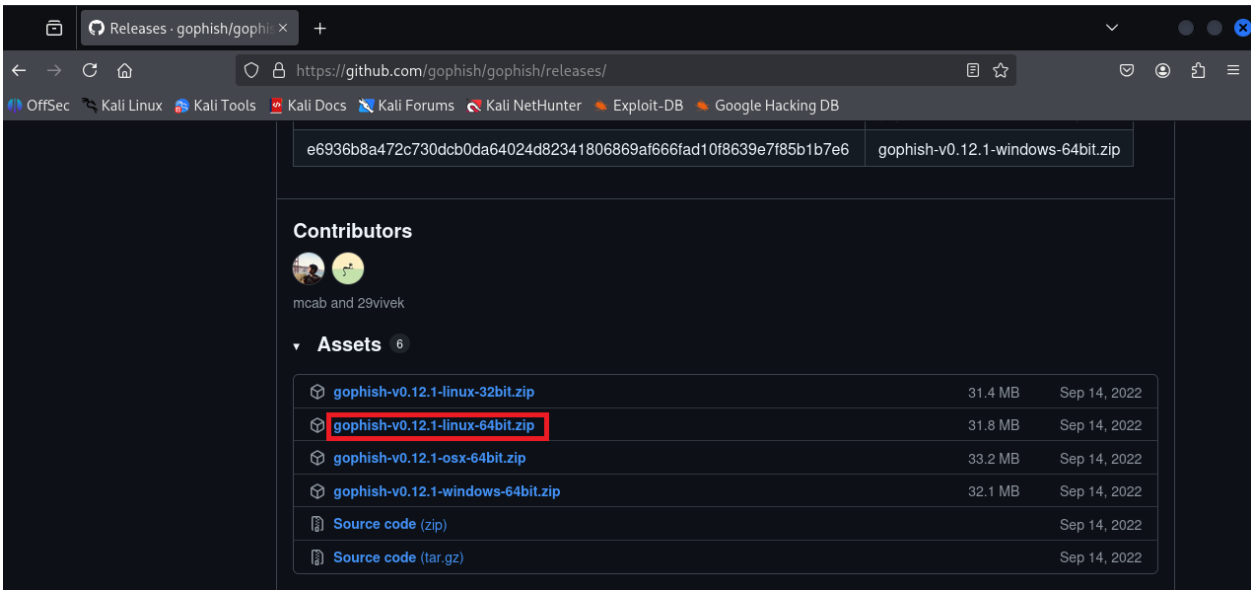
Các bước cài đặt:

1. Tải Gophish từ trang chính thức

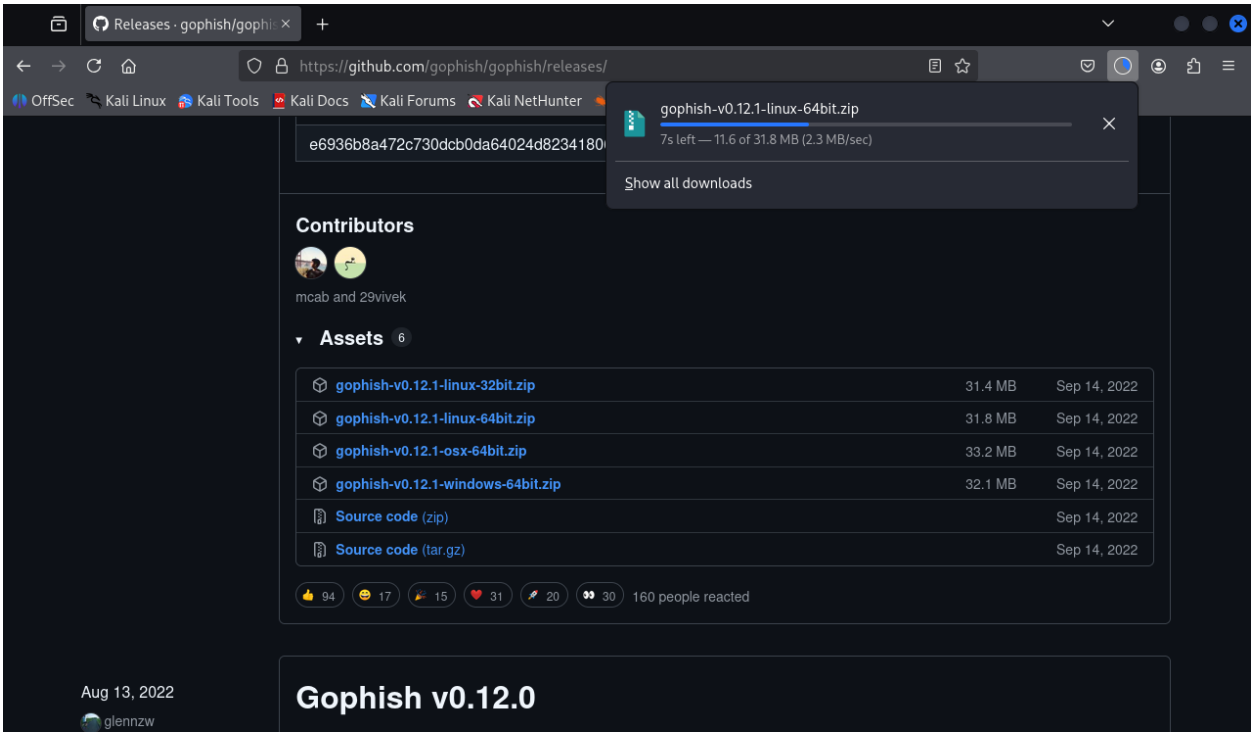




Click vào “release for your system”



Vì tôi đang sử dụng máy Kali nên tôi sẽ chọn bảng cài đặt dành cho HDH linux.
Click vào để tải về



2. Giải nén
   Truy cập vào thư mục Downloads và sử dụng lệnh ‘ls’ để liệt kê tệp đã tải xuống.

```
kali@kali: ~/Downloads
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ cd Downloads

┌──(kali㉿kali)-[~/Downloads]
└─$ ls
gophish-v0.12.1-linux-64bit.zip  thm.ovpn

┌──(kali㉿kali)-[~/Downloads]
└─$
```

Chúng ta sẽ tạo 1 thư mục để lưu trữ các tệp sẽ giải nén.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ mkdir gophish
```

Sử dụng lệnh ‘mkdir gophish’.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ unzip gophish-v0.12.1-linux-64bit.zip -d gophish/
```

Sử dụng lệnh ‘unzip’ để giải nén và lưu vào thư mục gophish đã tạo trước đó.

```
kali@kali: ~/Downloads
Session  Actions  Edit  View  Help
  inflating: gophish/db/db_sqlite3/migrations/20160317214457_0.2_redirect_url.sql
  inflating: gophish/db/db_sqlite3/migrations/20160131153104_0.1.2_add_event_details.sql
  inflating: gophish/db/db_sqlite3/migrations/20200116000000_0.9.0_imap.sql
  inflating: gophish/db/db_sqlite3/migrations/20171208201932_0.4.1_next_send_date.sql
  inflating: gophish/db/db_sqlite3/migrations/20180524203752_0.7.0_result_last_modified.sql
  inflating: gophish/db/db_sqlite3/migrations/20190105192341_0.8.0_rbac.sql
  inflating: gophish/db/db_sqlite3/dbconf.yml
   creating: gophish/templates/
  inflating: gophish/templates/settings.html
  inflating: gophish/templates/reset_password.html
  inflating: gophish/templates/dashboard.html
  inflating: gophish/templates/sending_profiles.html
  inflating: gophish/templates/groups.html
  inflating: gophish/templates/landing_pages.html
  inflating: gophish/templates/flashes.html
  inflating: gophish/templates/login.html
  inflating: gophish/templates/base.html
  inflating: gophish/templates/nav.html
  inflating: gophish/templates/users.html
  inflating: gophish/templates/campaign_results.html
  inflating: gophish/templates/campaigns.html
  inflating: gophish/templates/webhooks.html
  inflating: gophish/templates/templates.html
  inflating: gophish/README.md
 extracting: gophish/VERSION
  inflating: gophish/LICENSE
  inflating: gophish/config.json
```

Sử dụng lệnh ‘ls’ để kiểm tra lại

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ls
gophish  gophish-v0.12.1-linux-64bit.zip
```

Truy cập vào thư mục ‘gophish’ bằng lệnh ‘cd gophish’. Sử dụng lệnh ‘ls’ để liệt kê các tệp trong thư mục.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ cd gophish

┌──(kali㉿kali)-[~/Downloads/gophish]
└─$ ls
config.json  db  gophish  LICENSE  README.md  static  templates  VERSION
```

Chúng ta sẽ cấp quyền thực thi cho tệp bằng lệnh ‘sudo chmod u+x gophish’

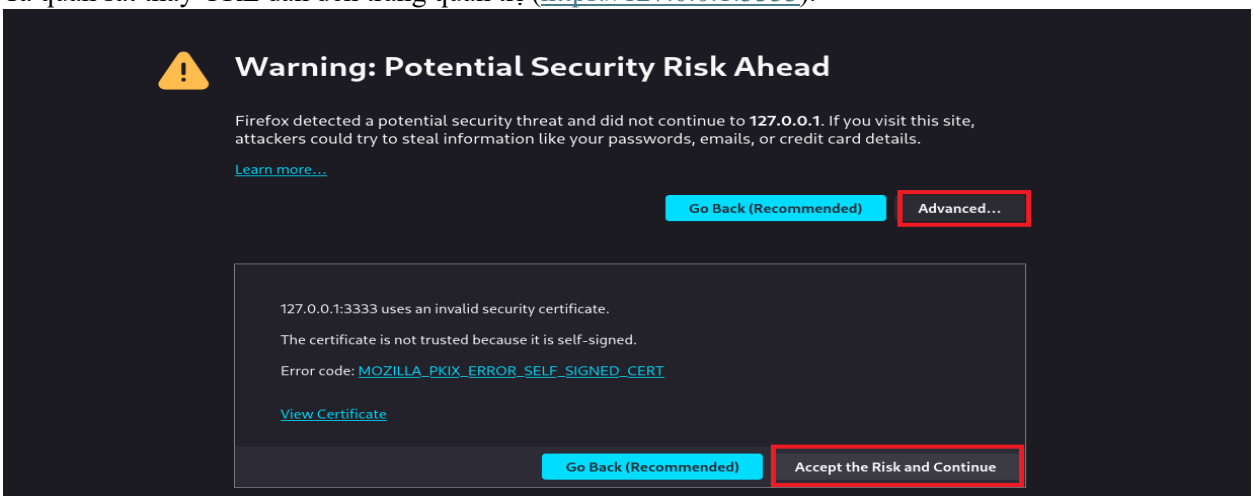
```
┌──(kali㉿kali)-[~/Downloads/gophish]
└─$ sudo chmod u+x gophish
```

3. Khởi động chương trình và đổi mật khẩu mặc định
   Để khởi động gophish, ta sử dụng lệnh ‘sudo ./gophish’

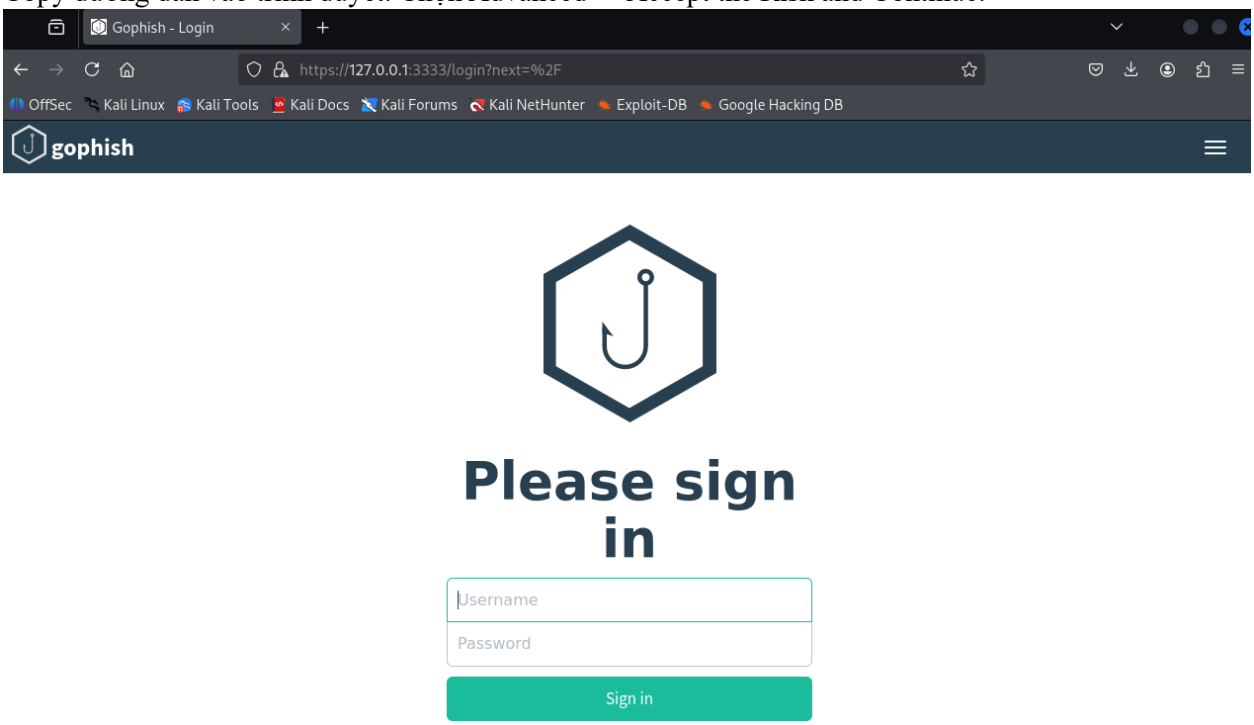
```
┌──(kali㉿kali)-[~/Downloads/gophish]
└─$ sudo ./gophish
```

```
kali@kali: ~/Downloads/gophish
Session  Actions  Edit  View  Help
OK    20160225173824_0.1.2_capture_credentials.sql
OK    20160227180335_0.1.2_store-smtp-settings.sql
OK    20160317214457_0.2_redirect_url.sql
OK    20160605210903_0.2_campaign_scheduling.sql
OK    20170104220731_0.2_result_statuses.sql
OK    20170219122503_0.2.1_email_headers.sql
OK    20170827141312_0.4_utc_dates.sql
OK    20171027213457_0.4.1_maillogs.sql
OK    20171208201932_0.4.1_next_send_date.sql
OK    20180223101813_0.5.1_user_reporting.sql
OK    20180524203752_0.7.0_result_last_modified.sql
OK    20180527213648_0.7.0_store_email_request.sql
OK    20180830215615_0.7.0_send_by_date.sql
OK    20190105192341_0.8.0_rbac.sql
OK    20191104103306_0.9.0_create_webhooks.sql
OK    20200116000000_0.9.0_imap.sql
OK    20200619000000_0.11.0_password_policy.sql
OK    20200730000000_0.11.0_imap_ignore_cert_errors.sql
OK    20200914000000_0.11.0_last_login.sql
OK    20201201000000_0.11.0_account_locked.sql
OK    20220321133237_0.4.1_envelope_sender.sql
time="2026-02-27T10:54:38-05:00" level=info msg="Please login with the username admin and the password 065b8f31e649067c"
time="2026-02-27T10:54:38-05:00" level=info msg="Creating new self-signed certificates for administration interface"
time="2026-02-27T10:54:38-05:00" level=info msg="Background Worker Started Successfully - Waiting for Campaigns"
time="2026-02-27T10:54:38-05:00" level=info msg="Starting phishing server at http://0.0.0.0:80"
time="2026-02-27T10:54:38-05:00" level=info msg="Starting IMAP monitor manager"
time="2026-02-27T10:54:38-05:00" level=info msg="Starting new IMAP monitor for user admin"
time="2026-02-27T10:54:38-05:00" level=info msg="TLS Certificate Generation complete"
time="2026-02-27T10:54:38-05:00" level=info msg="Starting admin server at https://127.0.0.1:3333"
```

Ta quan sát thấy URL dẫn đến trang quản trị (https://127.0.0.1:3333).

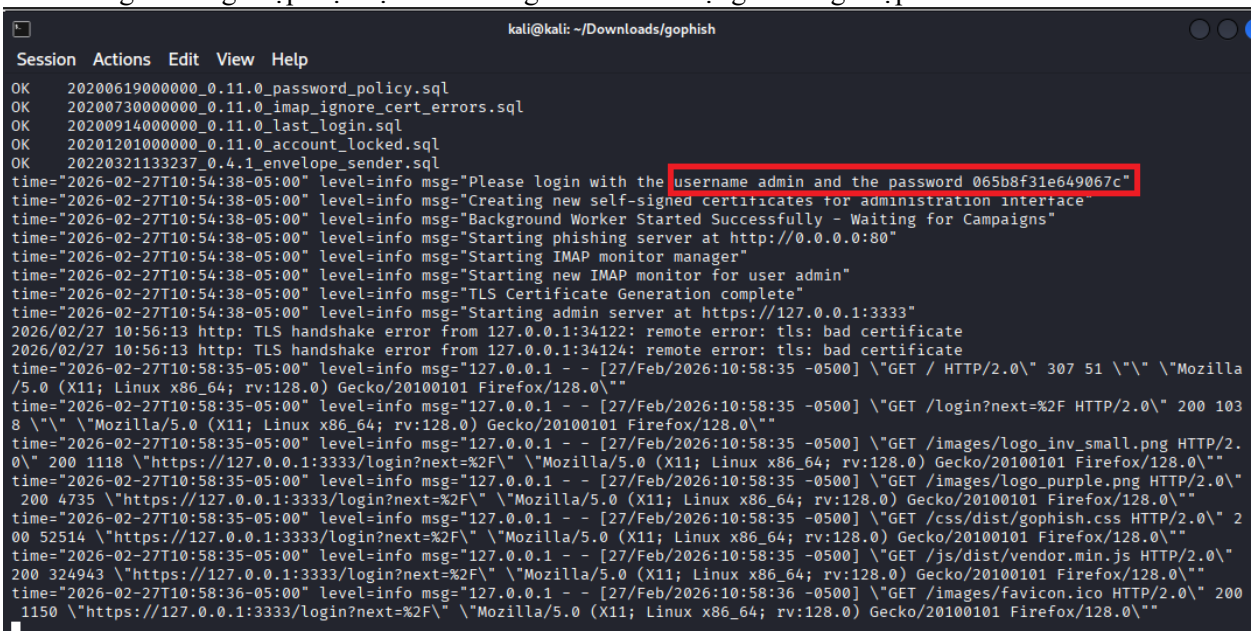


Copy đường dẫn vào trình duyệt. Chọn Advanced -> Accept the Risk and Continue.

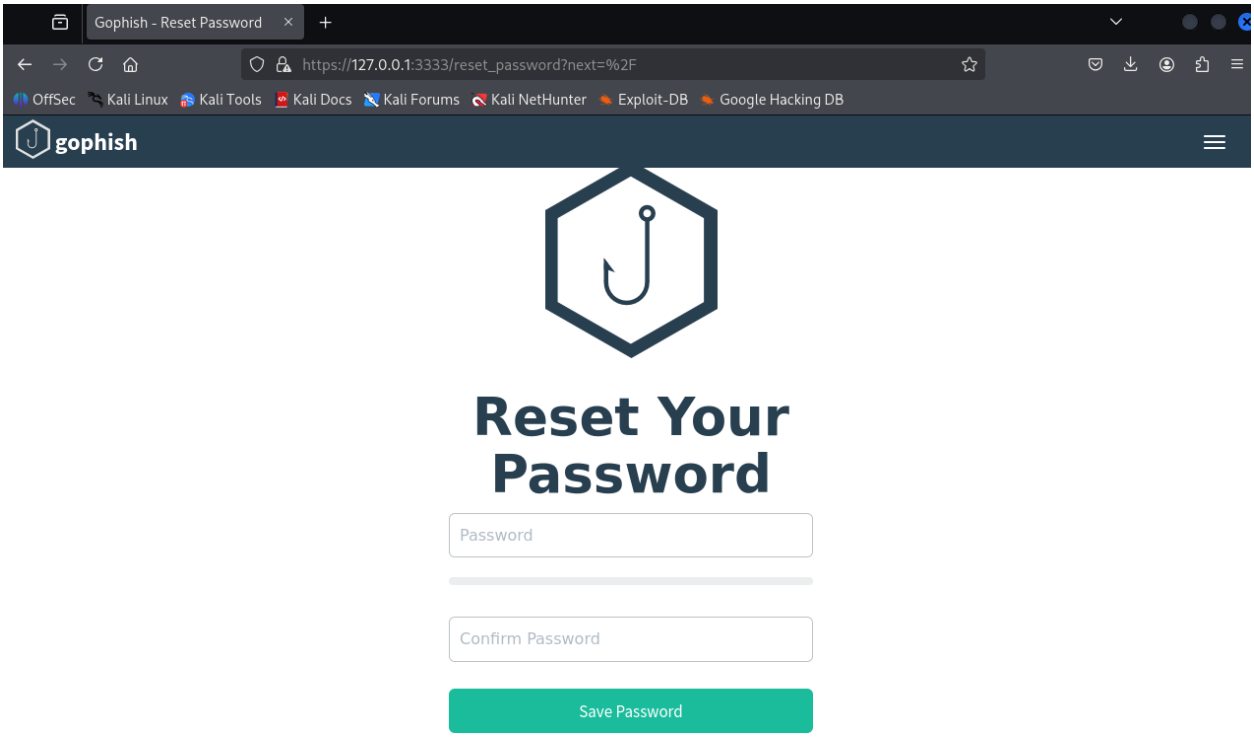


Ta quan sát thấy trang đăng nhập của Gophish.

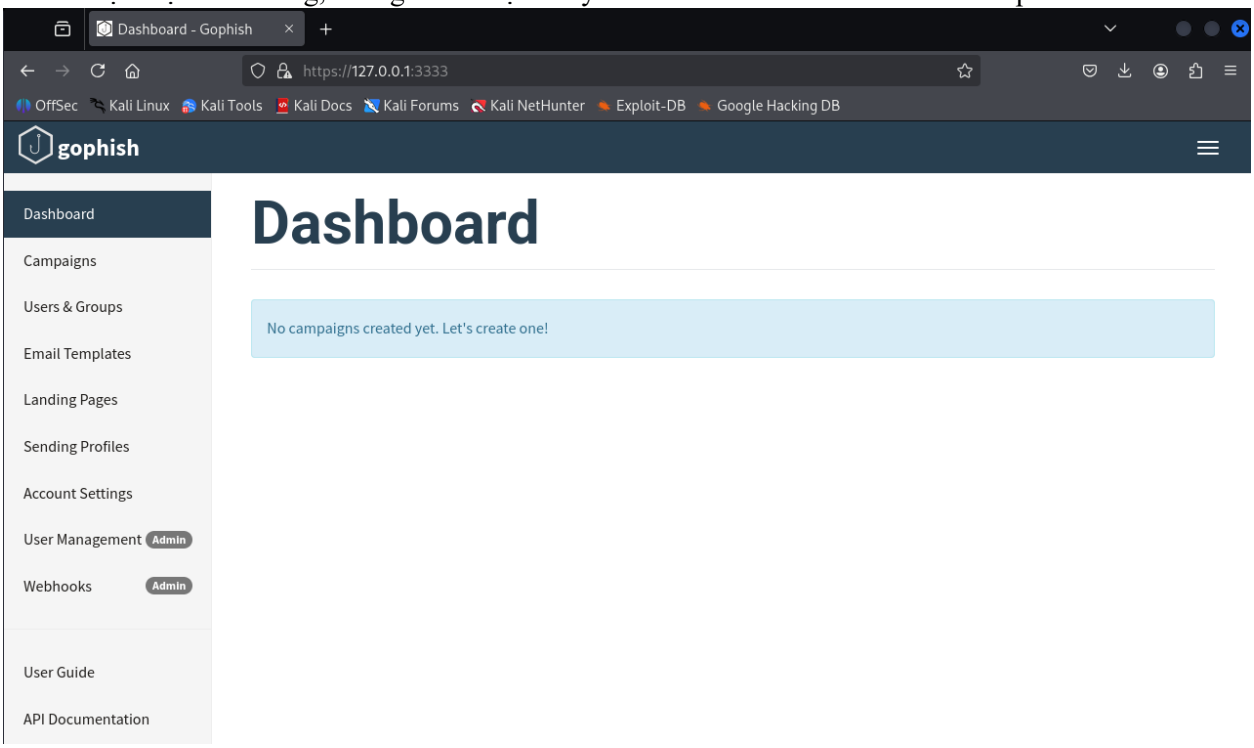
Để lấy thông tin đăng nhập, chúng ta kiểm tra màn hình terminal khi chạy Gophish lần đầu tiên, nó chứa thông tin đăng nhập mặc định mà chúng ta có thể sử dụng để đăng nhập lần đầu tiên.



Sử dụng thông tin đăng nhập được cấp sẵn để đăng nhập và tạo mật khẩu riêng.

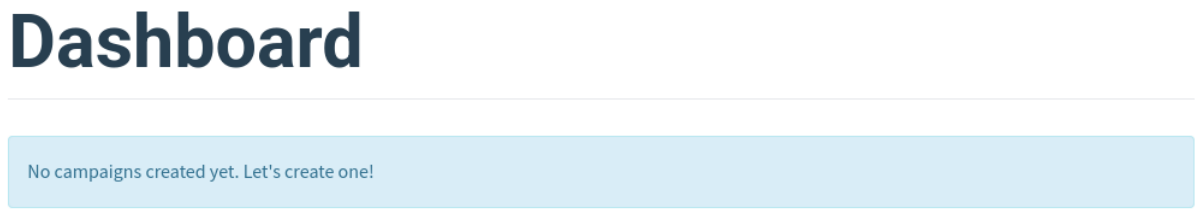


Sau khi tạo mật khẩu riêng, chúng ta sẽ được chuyển đến màn hình Dashboard của Gophish.



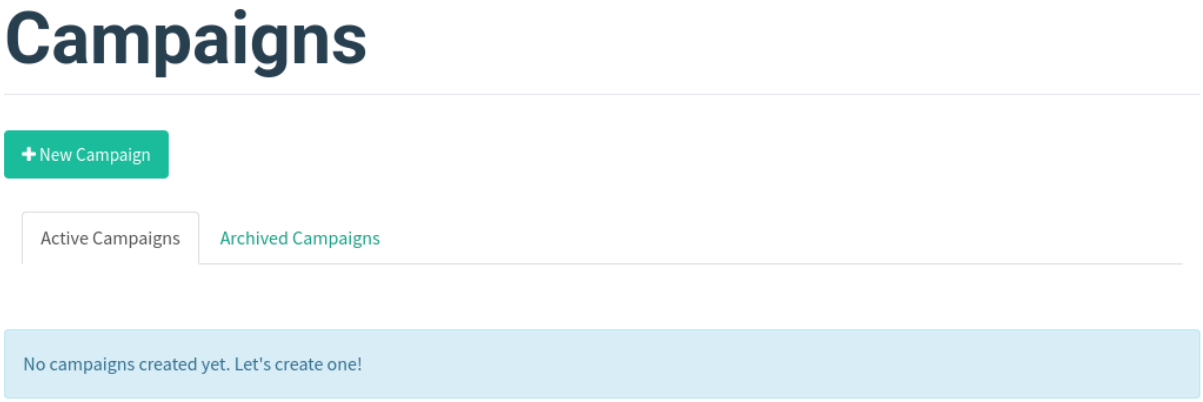
IV. Các thành phần chính của Gophish

1. Dashboard



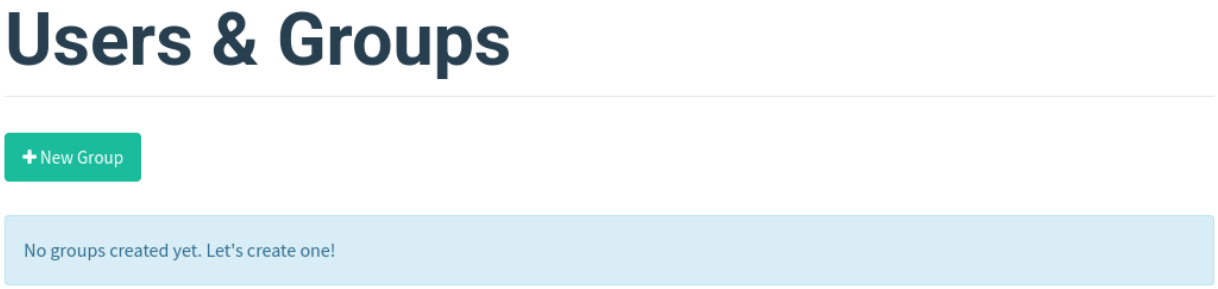
Hiển thị trạng thái tổng quan các campaign

2. Campaign



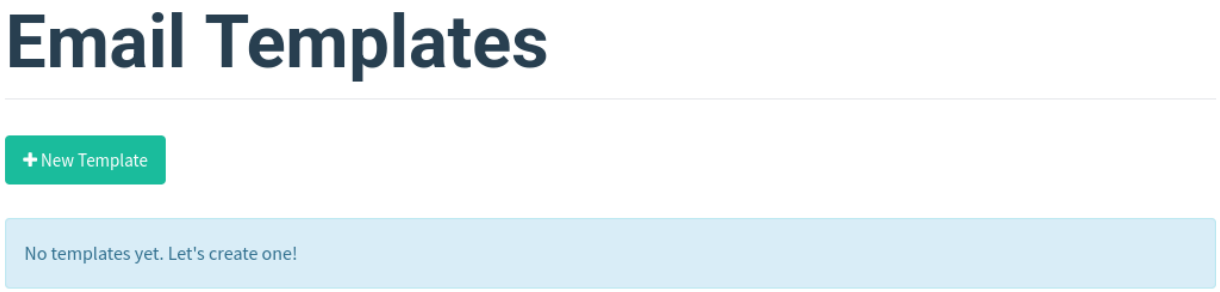
Nơi tạo và quản lí các campaign (chiến dịch) mô phỏng.

3. Users & Groups



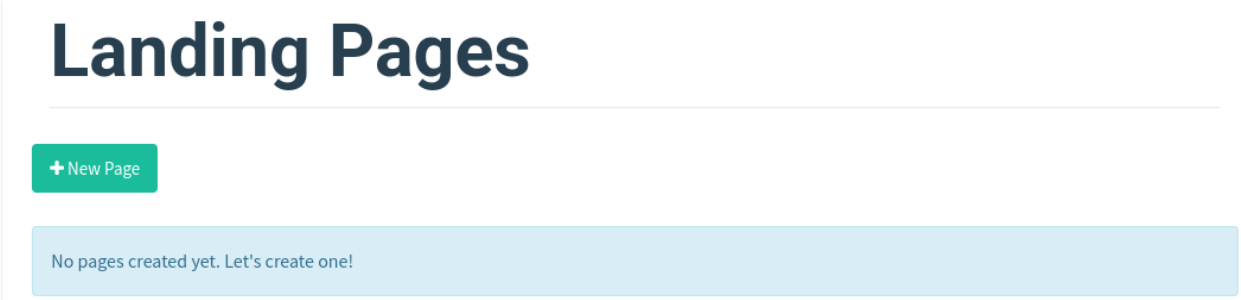
Quản lí danh sách người nhận

4. Email Templates



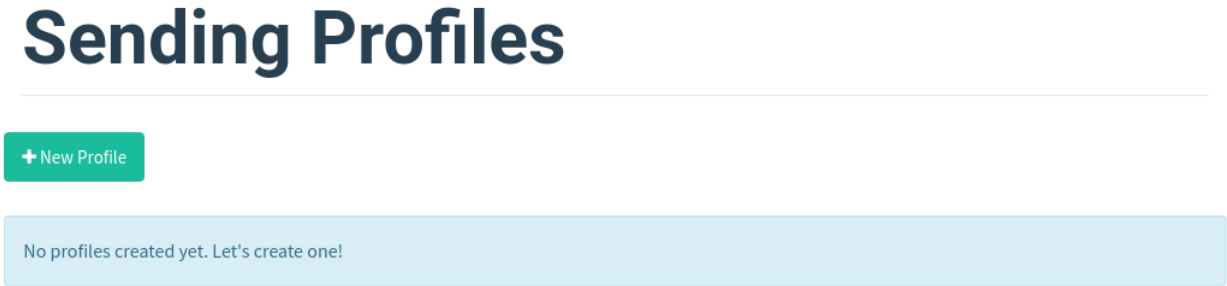
Tạo nội dung email mô phỏng

5. Landing Pages



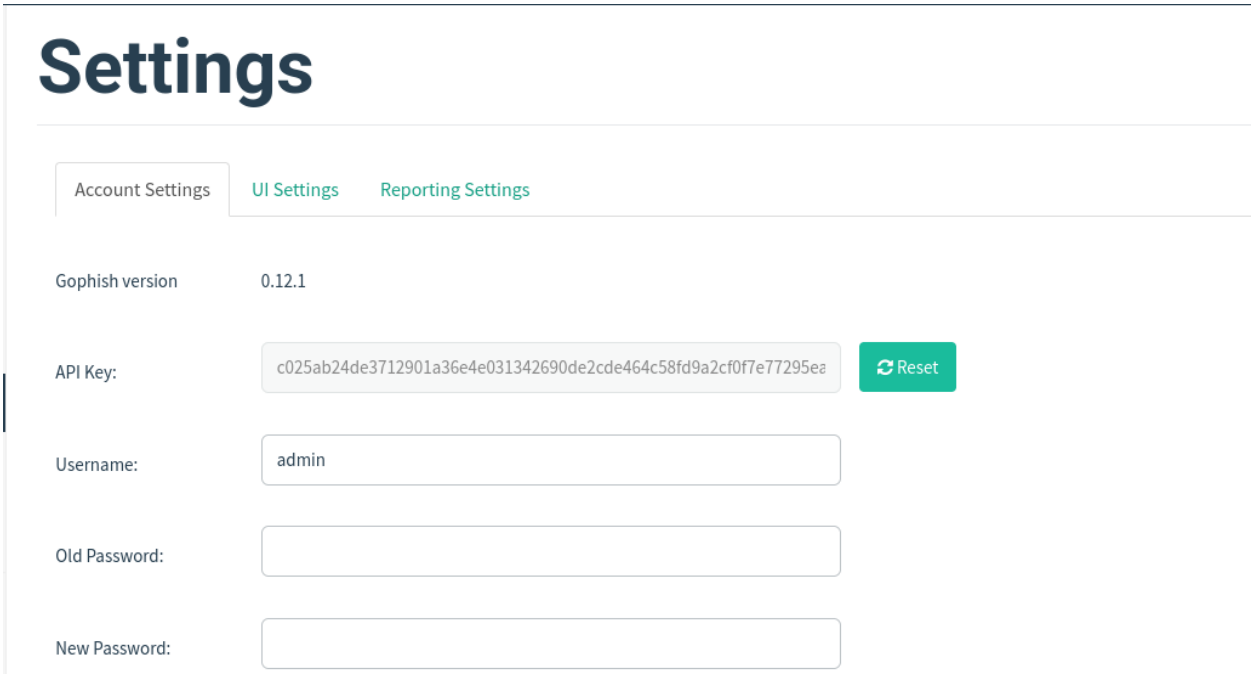
Quản lí trang đích khi người dùng click link

6. Sending Profiles



Cấu hình SMTP để gửi mail

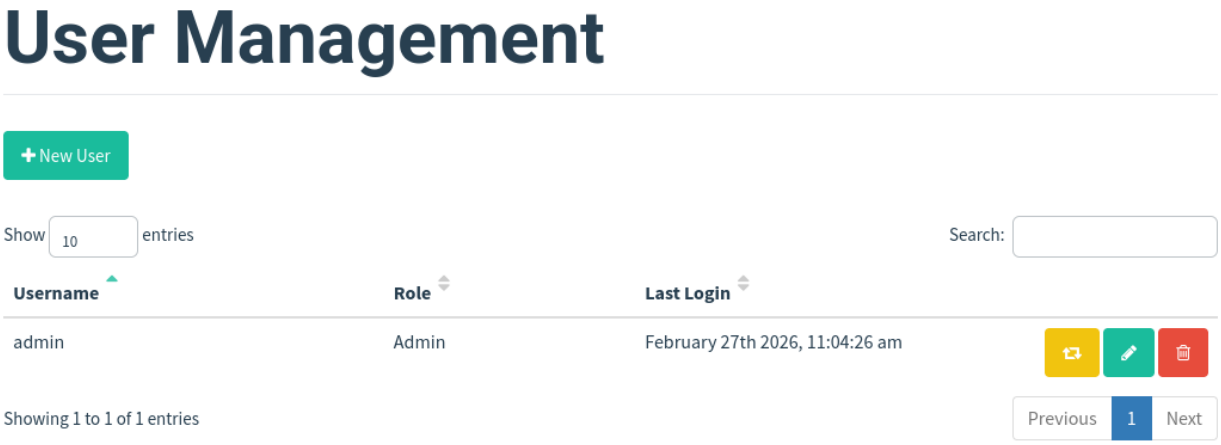
7. Account Settings



Cài đặt tài khoản:

- Đổi mật khẩu
- Cấu hình hệ thống
- API Key

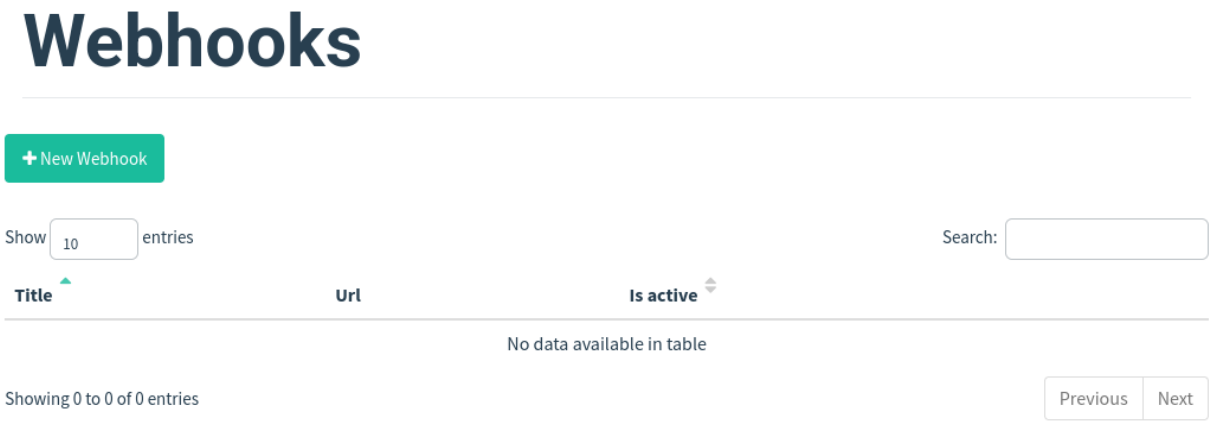
8. User Management



Quản lí người dùng hệ thống:

- Tạo tài khoản quản trị
- Phân quyền

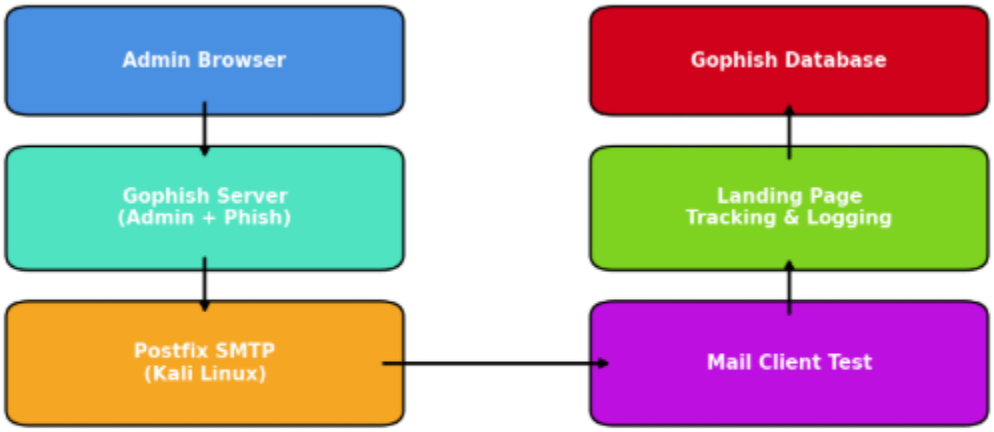
9. Webhooks



Cho phép tích hợp với các hệ thống bên ngoài:

- Gửi event sang SIEM
- Gửi thông báo Slack
- Tích hợp hệ thống SOC

V. Demo

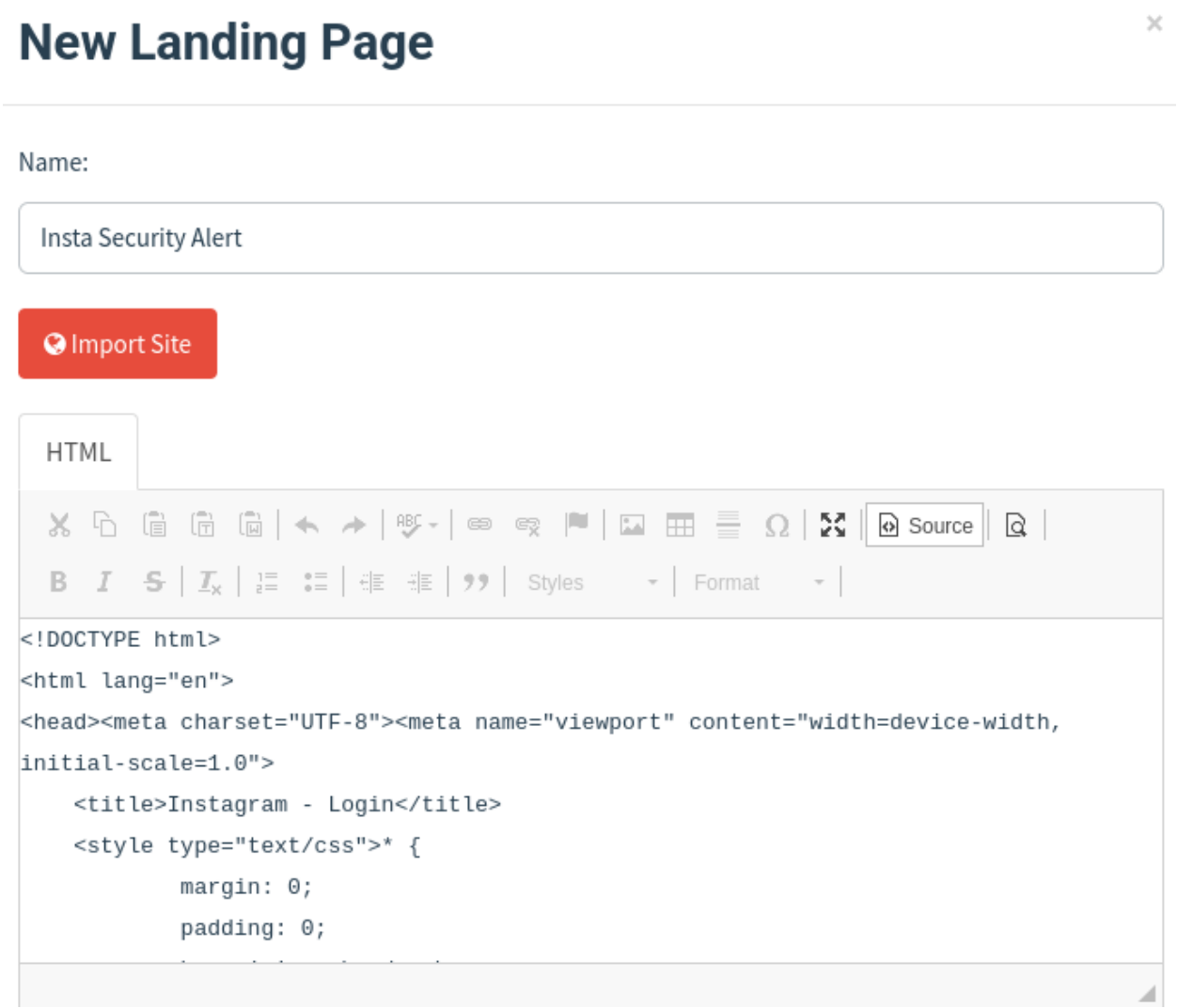


Trong kịch bản này, Gophish được triển khai trên Kali Linux và cấu hình gửi email thông qua Postfix SMTP nội bộ.

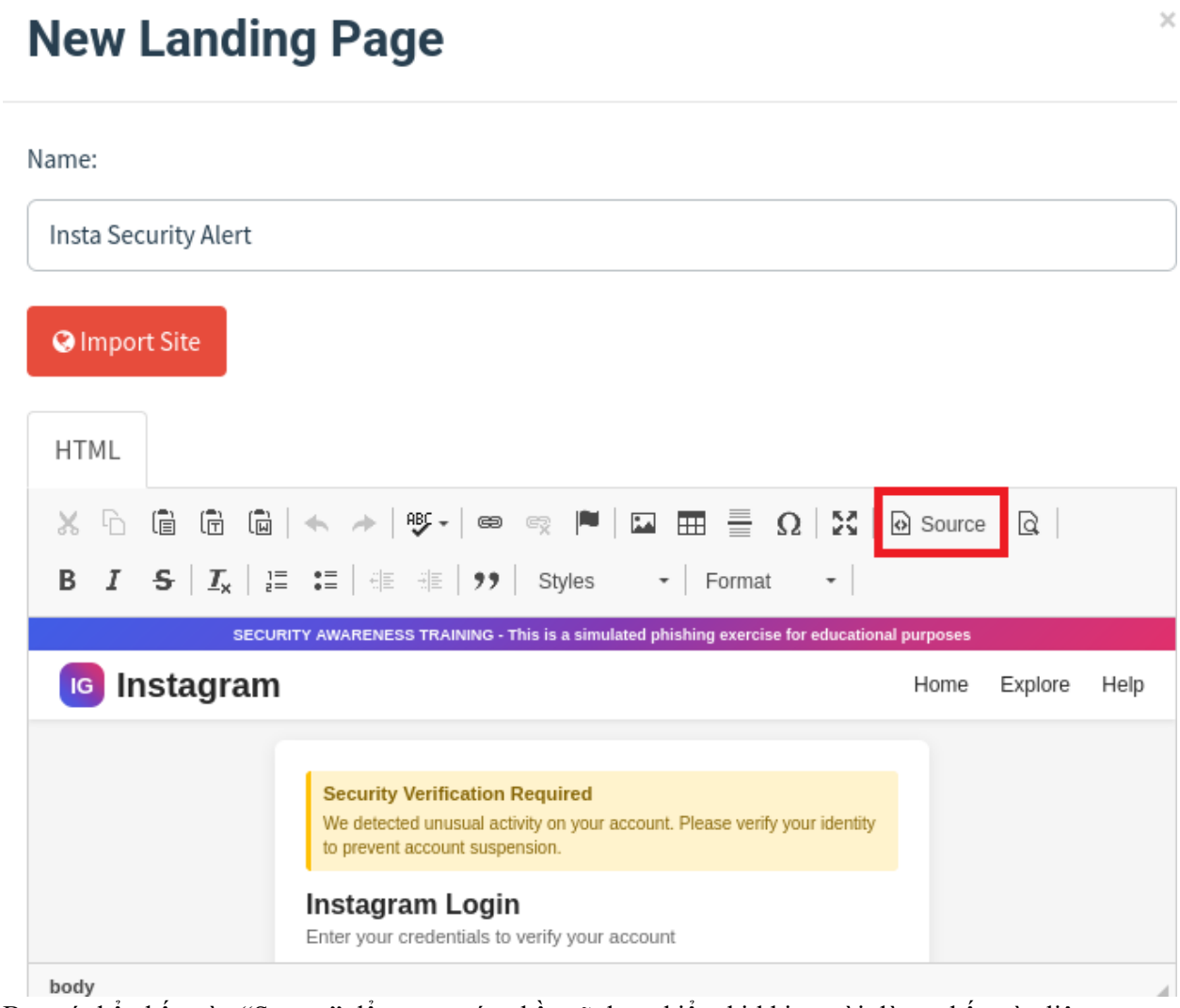
Postfix đóng vai trò chuyển tiếp email đến mailbox test.

Khi người dùng click liên kết, Gophish ghi nhận sự kiện và trả về landing page.

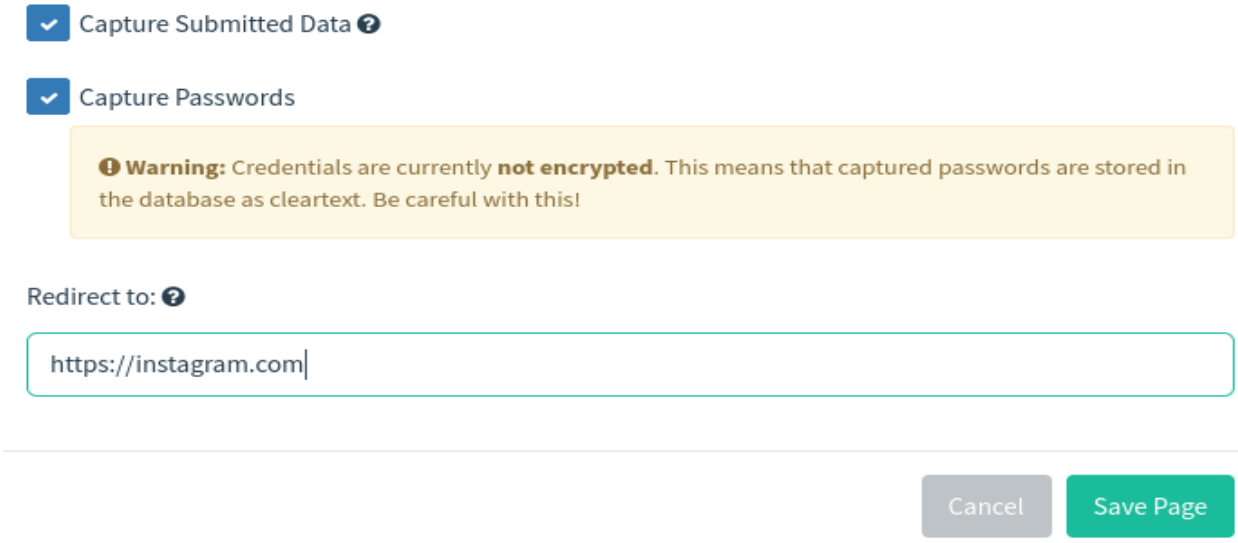
1. Chuẩn bị môi trường
   Trên kali:
   - Cài Gophish
   - Cài Postfix (SMTP nội bộ)
2. Cấu hình Landing Page
   Tôi sẽ tạo landing page có tên “Insta Security Alert”. Lưu ý, đây chỉ là tên quản trị nội bộ, nên bạn có thể đặt theo mong muốn.



   Ở phần HTML, đây là phần hiển thị cho người dùng, là ngôn ngữ dùng để xây dựng nội bộ trang web giả mạo.
   Ở đây tôi lấy source từ nguồn có sẵn https://github.com/rgsecteam/templates/blob/main/insta/index.html

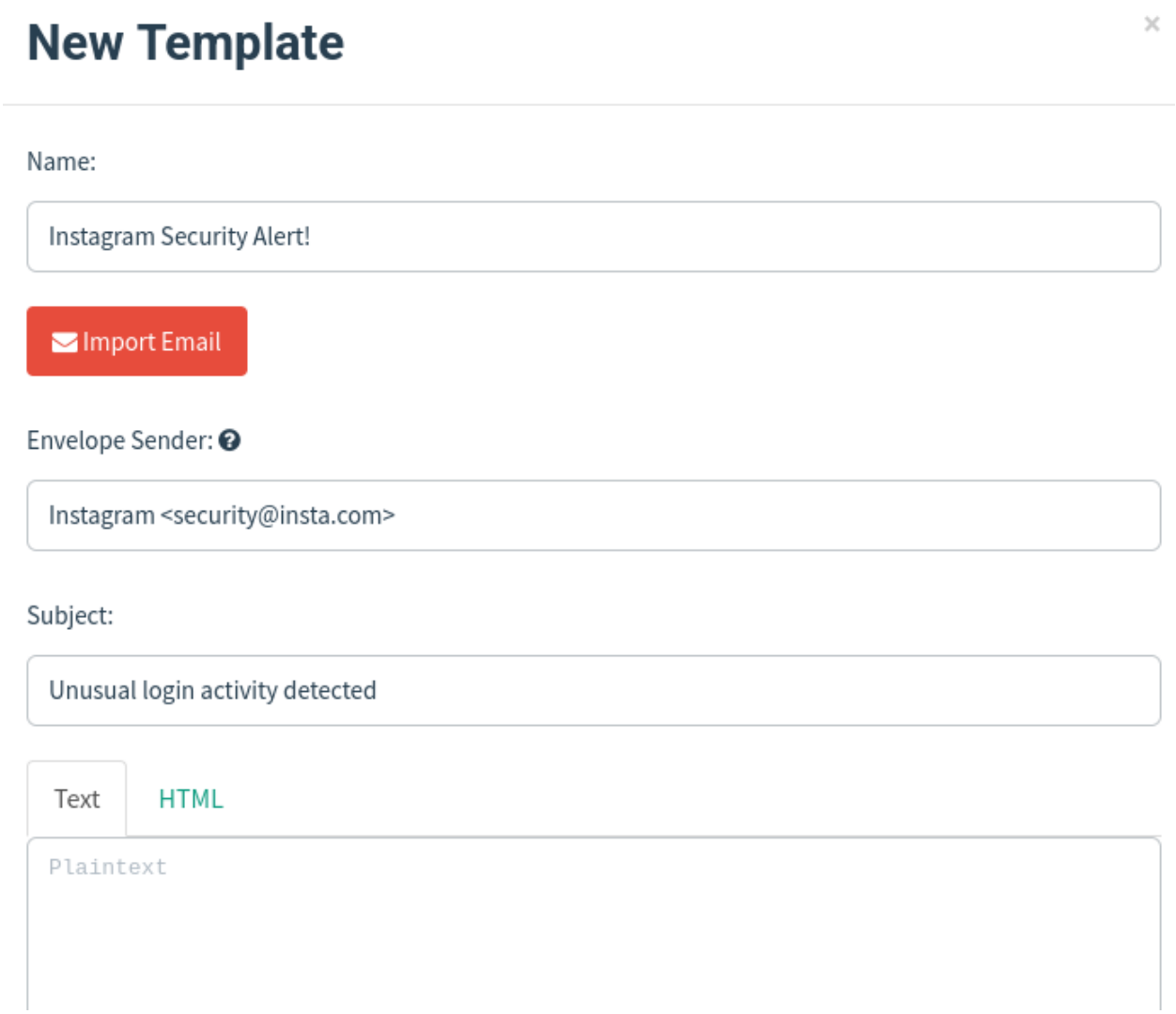


Bạn có thể nhấn vào “Source” để xem trước phần sẽ được hiển thị khi người dùng nhấp vào liên kết.



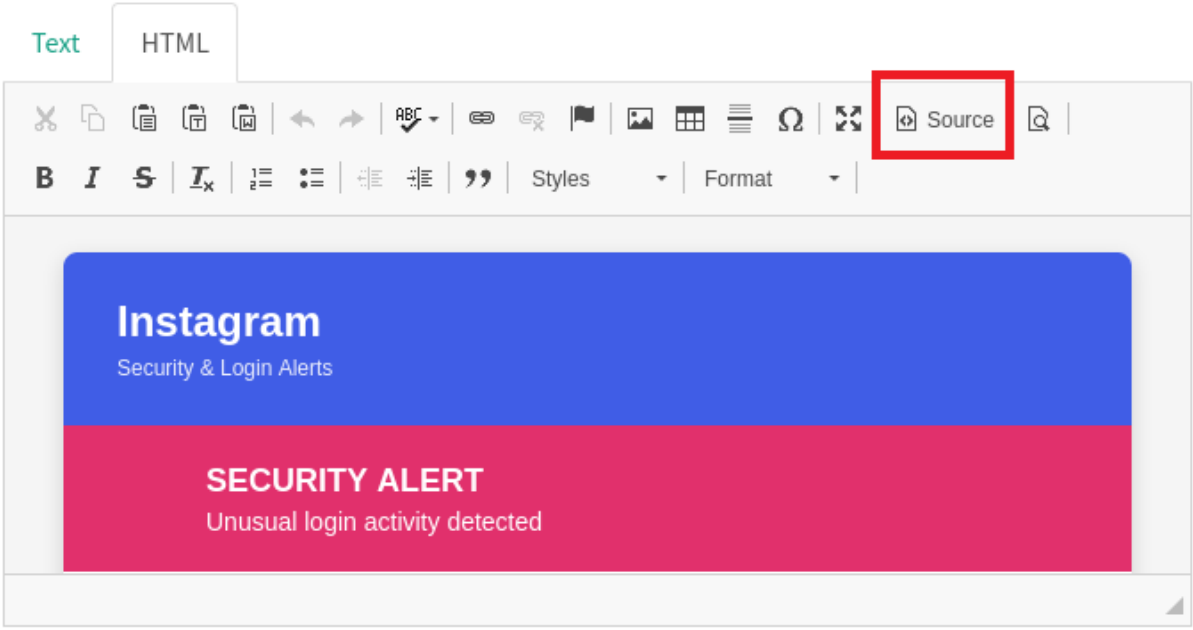
Tích vào “Capture Submitted Data” và “Capture Passwords”.
Ở phần Redirect to, chúng ta sẽ thiết lập URL chuyển hướng đến trang web instagram chính thức. Điều này có nghĩa là sau khi nạn nhân nhập thông tin, họ sẽ được chuyển đến trang web thật, khiến họ nghĩ rằng mình chỉ gặp phải 1 lỗi đăng nhập nhỏ.
Nhấn “Save Page”.

3. Cấu hình Email Templates



Ở mục Name, đây là tên nội bộ của Email Template trong Gophish, giúp phân biệt nhiều template khác nhau. Ở đây tôi sẽ đặt là “Instagram Security Alert!”.
Mục “Envelope Sender”: đây là địa chỉ người gửi mà người nhận sẽ nhìn thấy trong email.
Mục “Subject”: tiêu đề Email mà người nhận nhìn thấy.

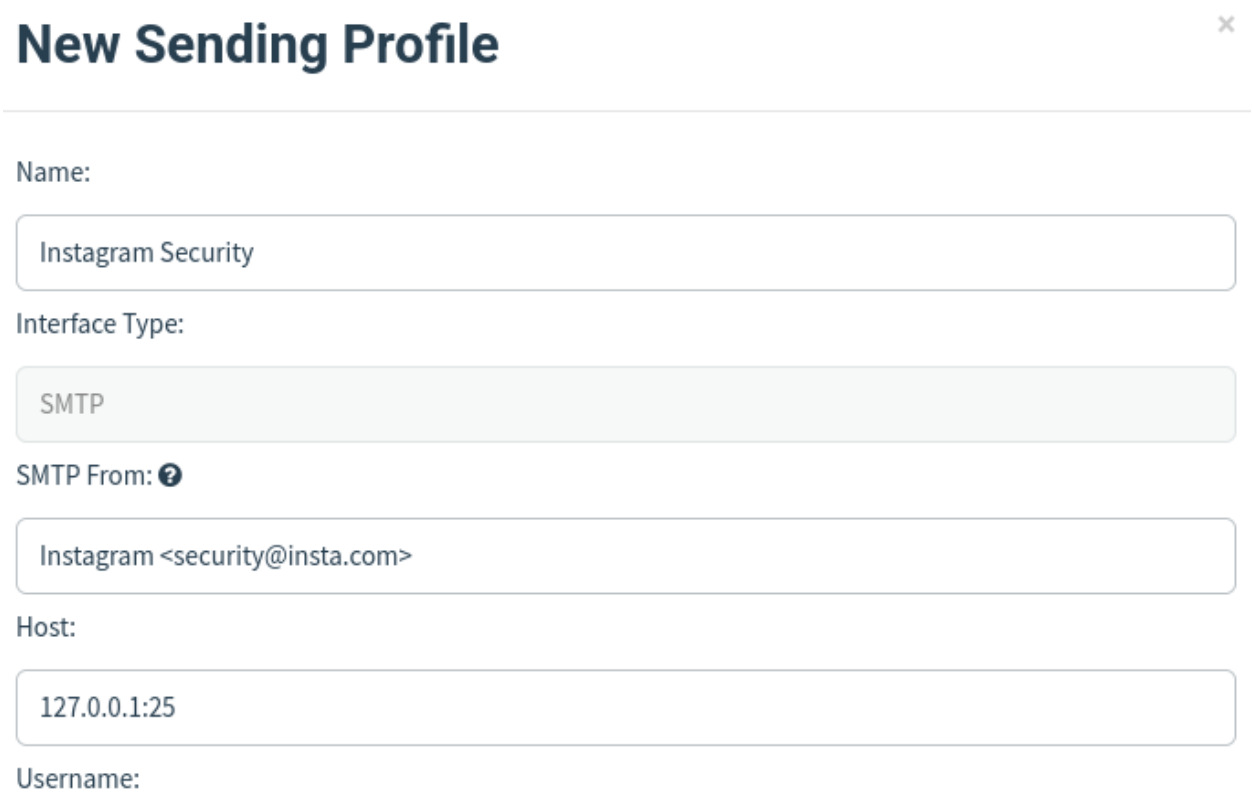
Ở phần HTML, chúng ta sử dụng một mẫu HTML được viết sẵn trông chuyên nghiệp. Các bạn có thể copy nội dung từ nguồn:
https://github.com/rgsecteam/templates/blob/main/insta/email.html



Nhấn “Source” để quan sát trước trang web được hiển thị khi người dùng nhấp vào.

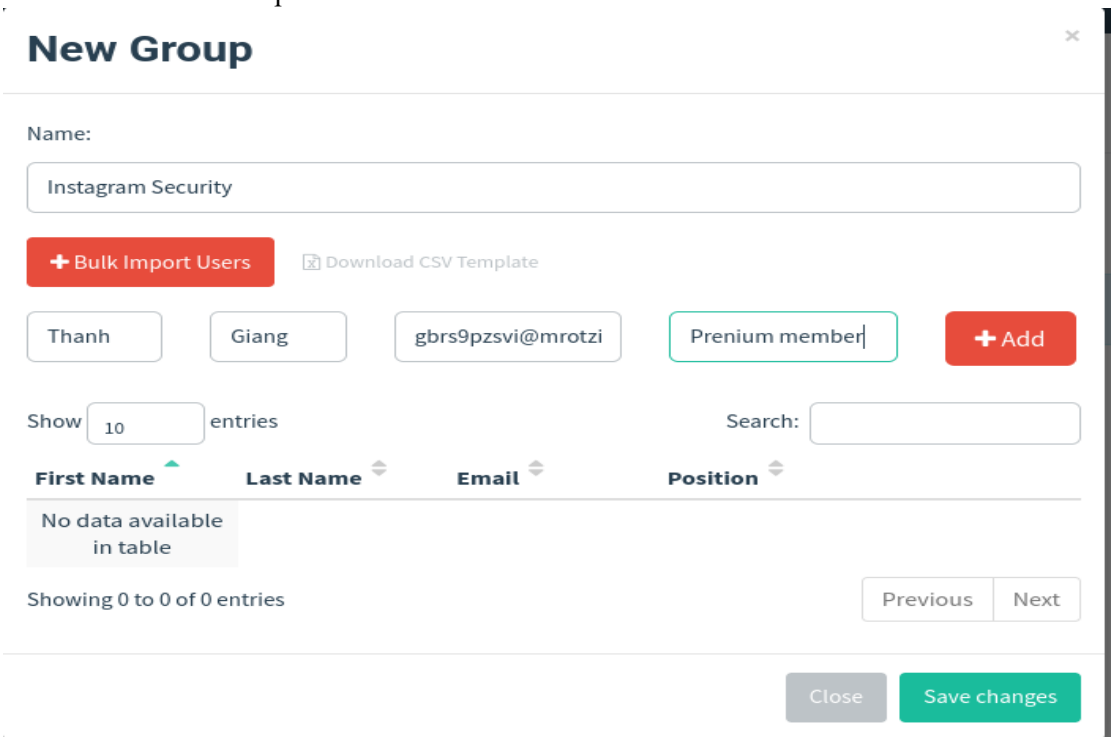
4. Cấu hình Sending Profiles

Đây là nơi chúng ta cấu hình máy chủ gửi thư đi

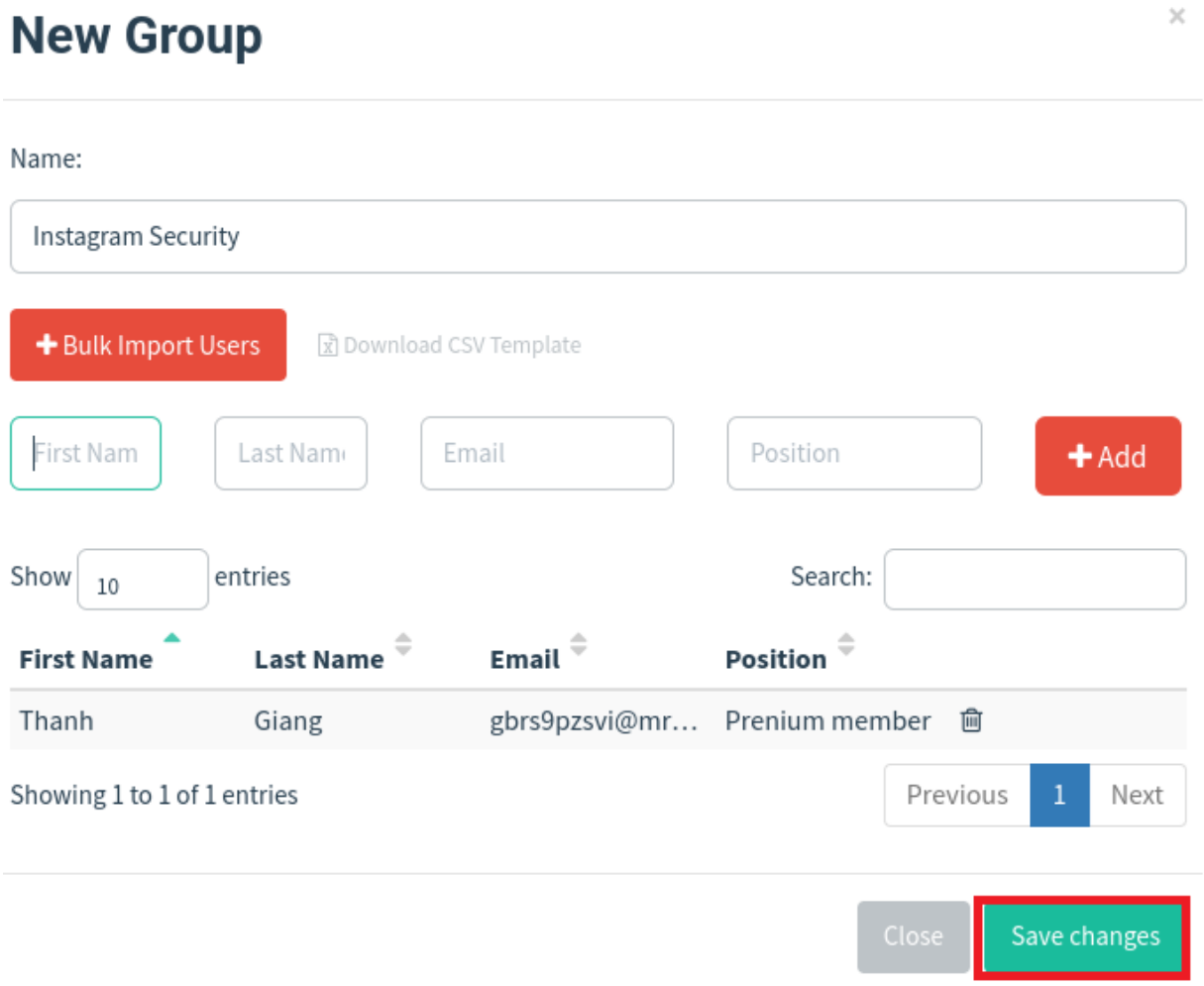


Ở mục “Host”: vì chúng ta đã cài đặt máy chủ thư Postfix cục bộ nên ta sẽ sử dụng địa chỉ IP của Gophish và số cổng 25.
Nhấn “Save Profile”.

5. Cấu hình Users & Groups



Ở đây tôi tạo 1 group có tên “Instagram Security”. Trong 1 cuộc tấn công thực tế, kẻ tấn công có thể mua hoặc thu thập danh sách địa chỉ email để phishing.
Ở đây tôi giả sử thêm mục tiêu theo cách thủ công.



Ấn “Save changes”, và mục tiêu sẽ được lưu.

6. Cấu hình Campaign

Name:

Instagram

Email Template:

Instagram Security Alert!

Landing Page:

Insta Security Alert

URL:

http://192.168.222.131

Launch Date

February 28th 2026, 1:20 am

Send Emails By (Optional)

Sending Profile:

Instagram Security

Send Test Email

Groups:

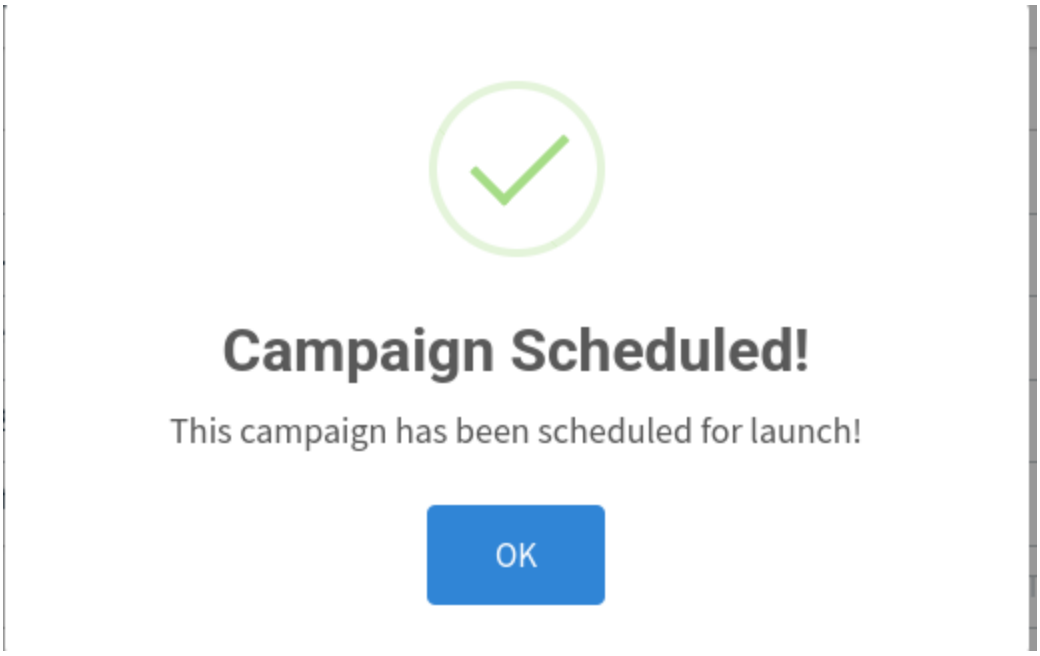
Ở mục URL, chúng ta sẽ nhập địa chỉ IP của máy tính cục bộ đang sử dụng.

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:bf:b4:c3 brd ff:ff:ff:ff:ff:ff
    inet 192.168.222.131/24 brd 192.168.222.255 scope global dynamic noprefixroute eth0
       valid_lft 905sec preferred_lft 905sec
    inet6 fe80::3efd:3287:4ace:da85/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

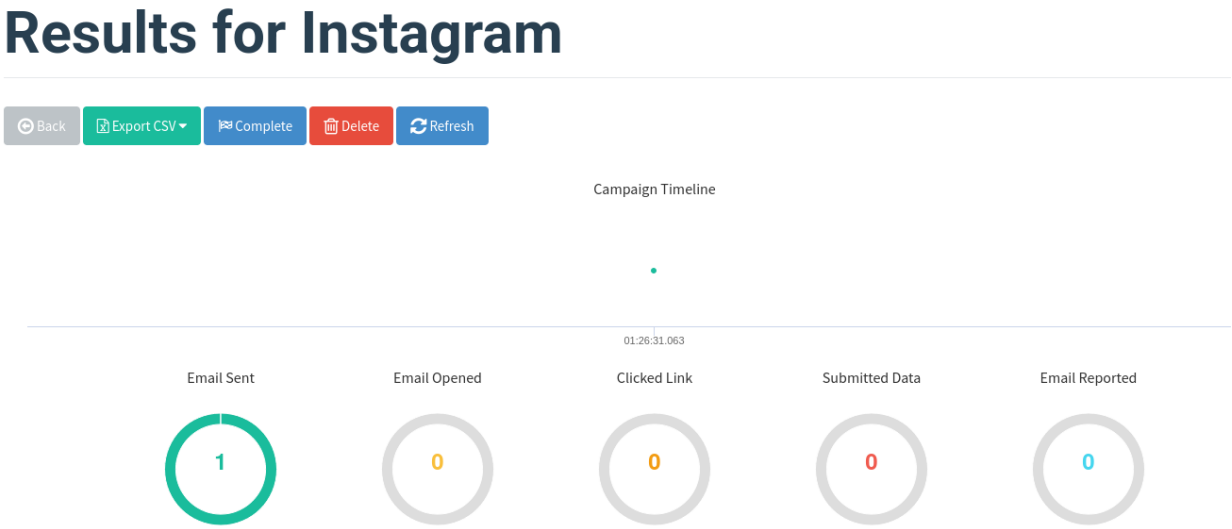
Ấn vào “Launch campaign” để bắt đầu chiến dịch.

Close

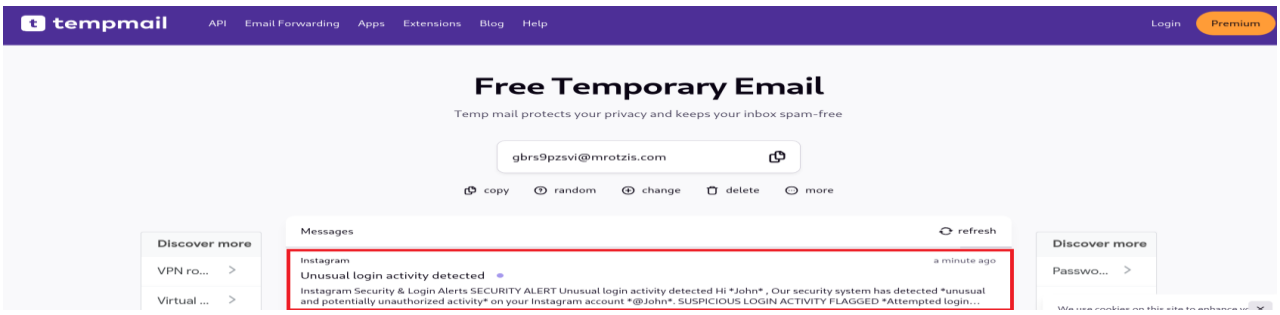
Launch Campaign



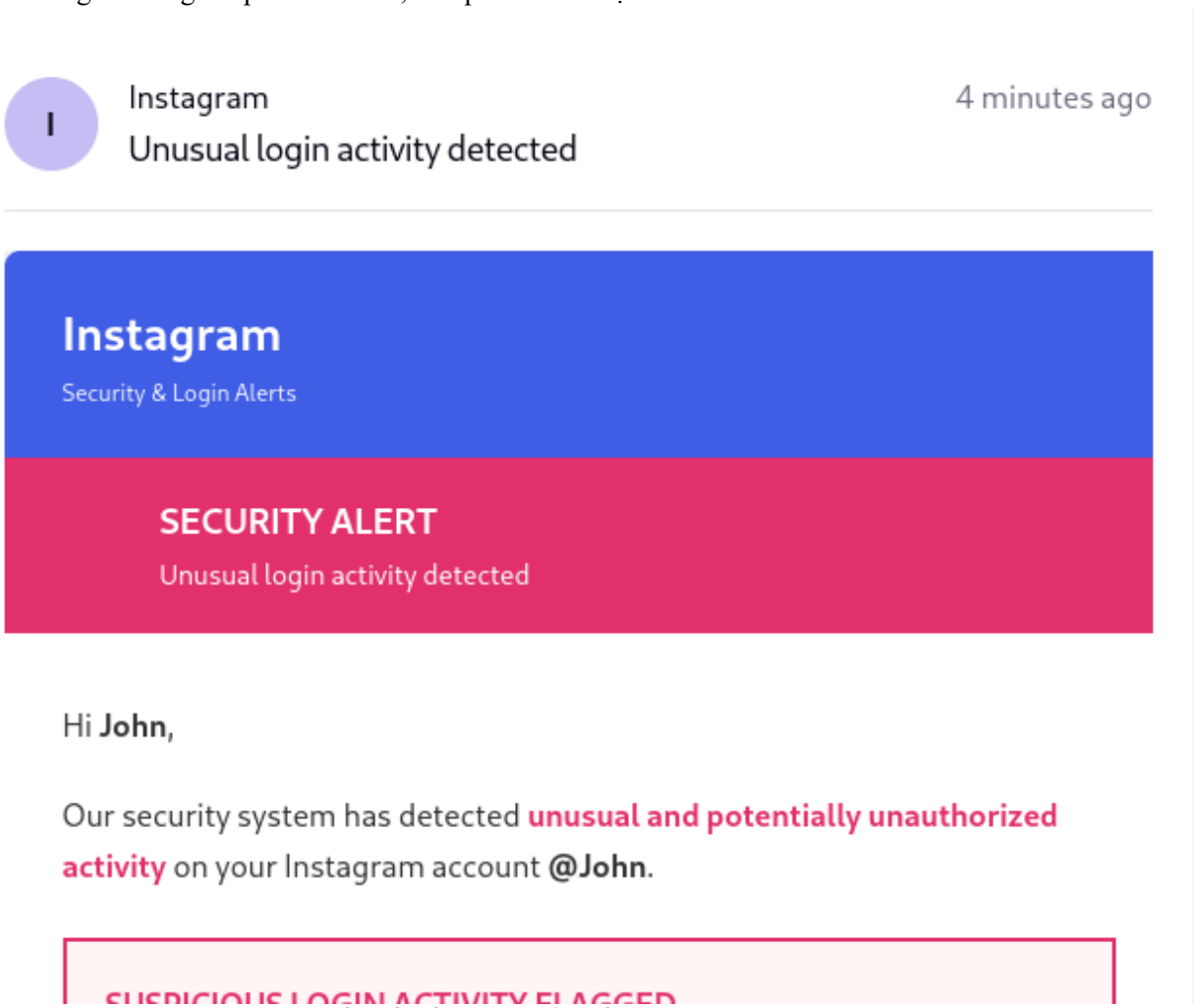
Kết quả hiển thị như trên.



7. Bắt đầu chiến dịch.
   Ở đây tôi sẽ sử dụng một email tạm thời thông qua trang web tempmail.
   Sau khi bắt đầu gửi campaign, mail tạm thời sẽ nhận được 1 message từ Gophish. Nó sẽ trông rất chuyên nghiệp như thể đến từ máy chủ Instgram.



Sau khi người dùng nhấp vào liên kết, kết quả sẽ hiển thị.



Là nạn nhân, chúng ta sẽ cảm thấy bối rối và có thể sẽ ấn vào “Verify My Account Now”.

IMMEDIATE ACTION REQUIRED:

You must verify your identity within **24 hours** or your account will be permanently suspended and all content archived pending investigation. This could result in:

- Complete loss of account access
- Inability to post or message followers
- Permanent deletion of your profile
- Loss of all photos and videos

Verify My Account Now

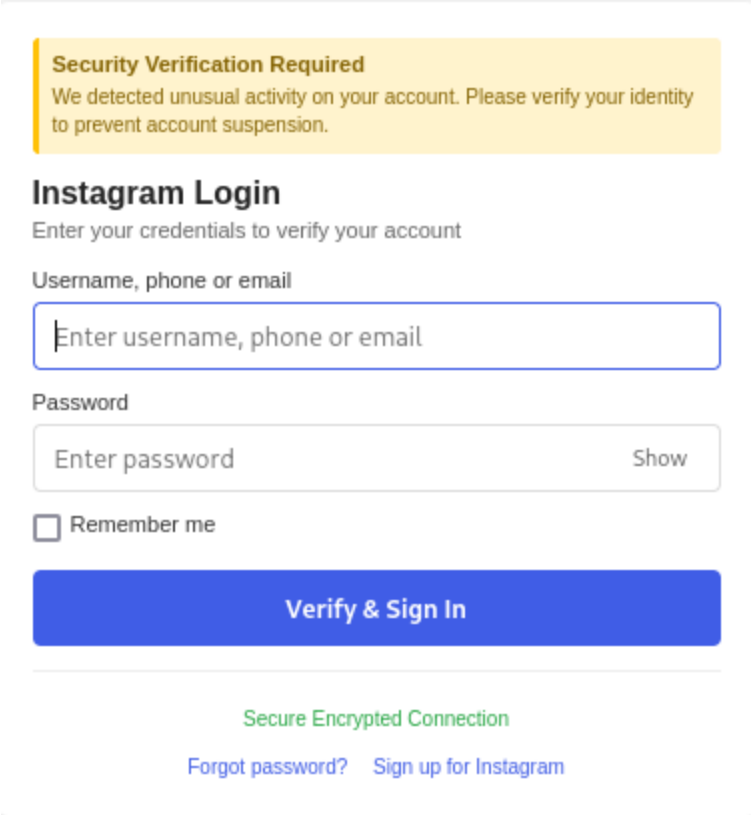
Time Remaining to Verify

24:00:00

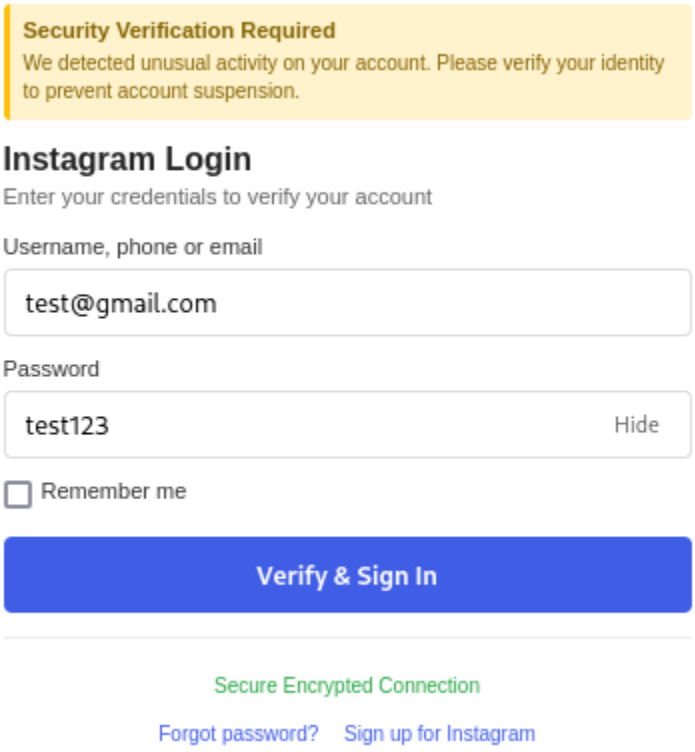
Account will be suspended after this time

If you do not recognize this activity, your account may be compromised. Act immediately to prevent unauthorized access and potential content loss.

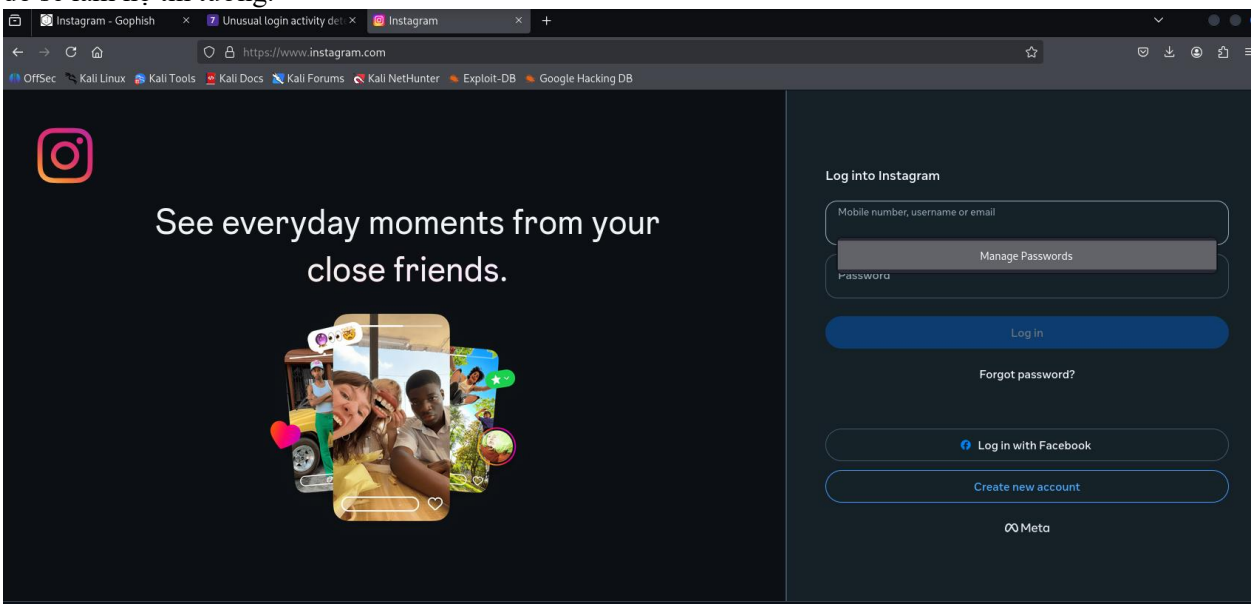
Sau khi người dùng ấn vào, họ sẽ được chuyển đến 1 trang đăng nhập.



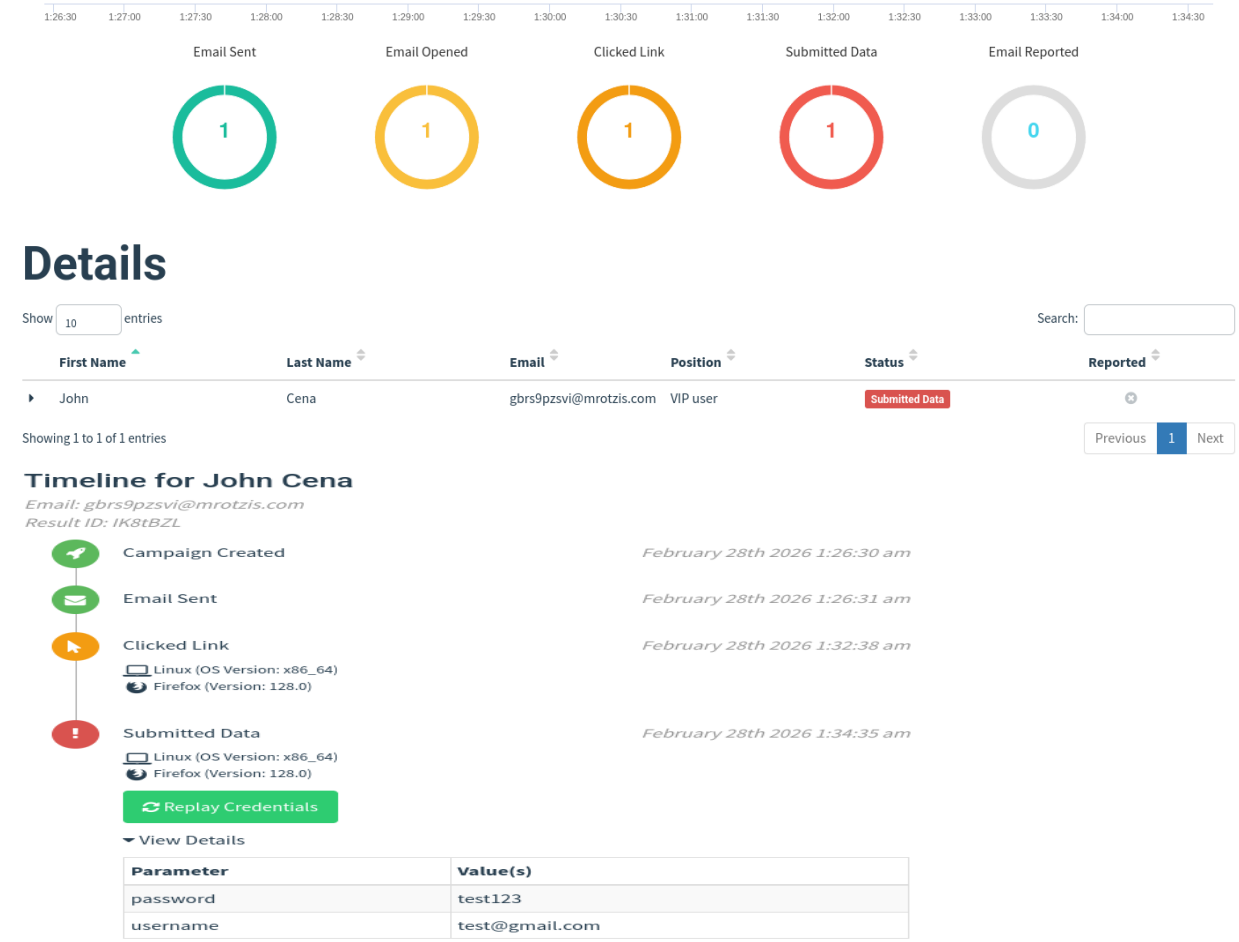
Ở đây, tôi sẽ thử đăng nhập bằng username và password không có thật.



Sau khi nhập thông tin, người dùng sẽ được chuyển tới trang web chính thức của Instagram, điều đó sẽ làm họ tin tưởng.



Quay lại trang quản lí Gophish, chúng ta quan sát thấy:



Vậy là chúng ta đã lấy được tài khoản và mật khẩu của nạn nhân.

VI. Đánh giá

Ưu điểm	Nhược điểm
Dễ triển khai	Phụ thuộc SMTP
Tracking chi tiết	Open tracking không chính xác 100%
Có REST API	Cần cấu hình DNS khi gửi ra Internet
Nhẹ và ổn định	Không phù hợp enterprise lớn nếu không scale

Trong môi trường lab, Gophish đáp ứng tốt yêu cầu mô phỏng phishing phục vụ đào tạo nhận thức. Hệ thống dễ triển khai, tiêu thụ tài nguyên thấp và cung cấp cơ chế tracking chi tiết. Tuy nhiên, khi triển khai ngoài môi trường nội bộ, cần cấu hình đầy đủ DNS, SMTP và các cơ chế xác thực email để đảm bảo khả năng gửi mail thành công.

VII. Đánh giá hiệu năng

Mục tiêu của bài kiểm thử là:

- Đánh giá khả năng xử lý concurrent request của Gophish
- Phân tích độ trễ phản hồi (latency)
- Xác định giới hạn chịu tải của hệ thống
- Phân tích bottleneck khi số lượng người dùng tăng cao

Kịch bản giả định:

100–1000 người dùng đồng thời nhấp vào liên kết phishing.

1. Môi trường thử nghiệm

- OS: Kali Linux
- CPU: 4 cores
- RAM: 2GB
- Database: SQLite (mặc định Gophish)
- Gophish chạy ở port 80
- Locust dùng để tạo tải

2. Cài đặt Locust

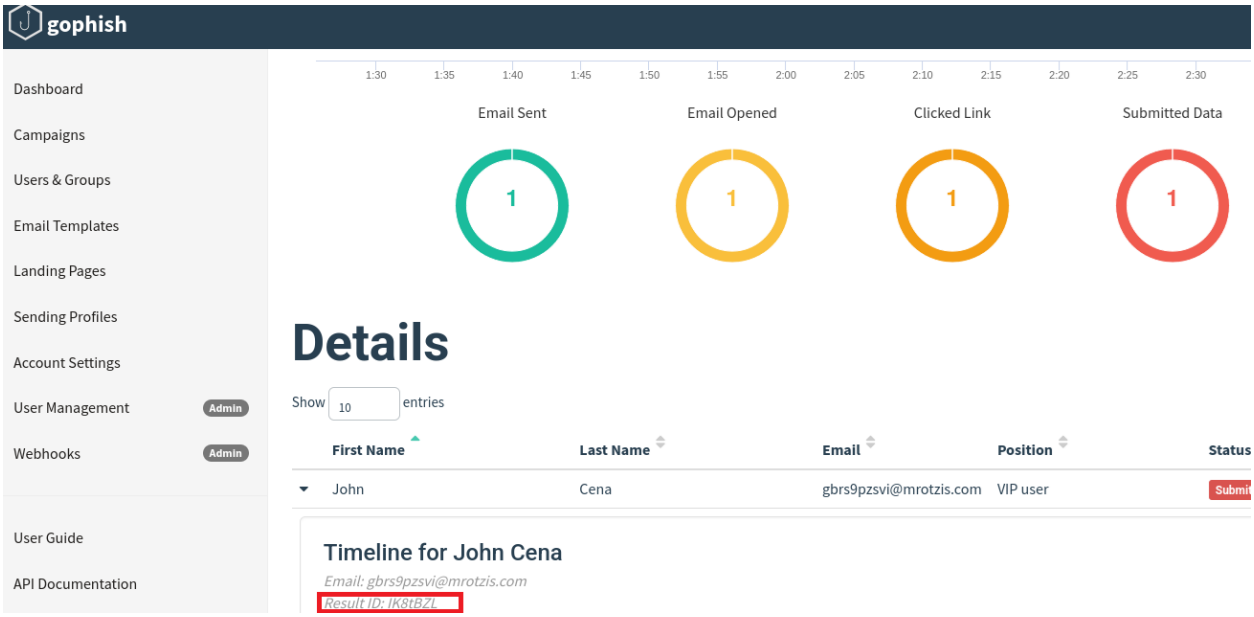
Để cài đặt Locust, ta sử dụng lệnh

Sudo apt install locust

3.

3. Lấy RID

Để có thể lấy RID, bạn có thể xem lại kết quả của phần demo trước.



4. Cấu hình file locust

Ta tạo file locustfile.py:

```
from locust import HttpUser, task, between

class ClickUser(HttpUser):
    wait_time = between(0.1, 0.2)

    @task
    def click(self):
        self.client.get("/?rid=IK8tBZL")
```

Giải thích:

- HttpUser: mô phỏng người dùng HTTP
- wait_time: thời gian nghỉ giữa các request
- self.client.get(): gửi request đến landing endpoint

5. Thực hiện kiểm thử

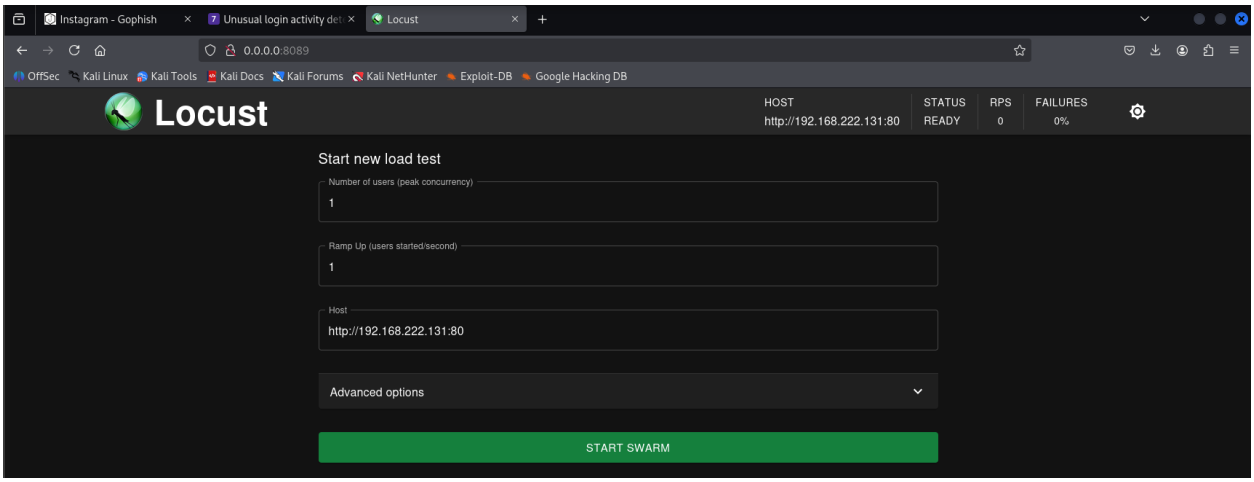
Chạy Locust:

```
┌──(kali㉿kali)-[~]
└─$ locust -H http://192.168.222.131:80
```

Ở đây, tôi chạy trên port 80 vì Gophish của tôi được cấu hình ở port 80, trên máy khác có thể là 8080.

```
┌──(kali㉿kali)-[~/Downloads/gophish]
└─$ locust -H http://192.168.222.131:80
[2026-02-28 03:20:38,107] kali/INFO/locust.main: Starting web interface at http://0.0.0.0:8089
[2026-02-28 03:20:38,119] kali/INFO/locust.main: Starting Locust
```

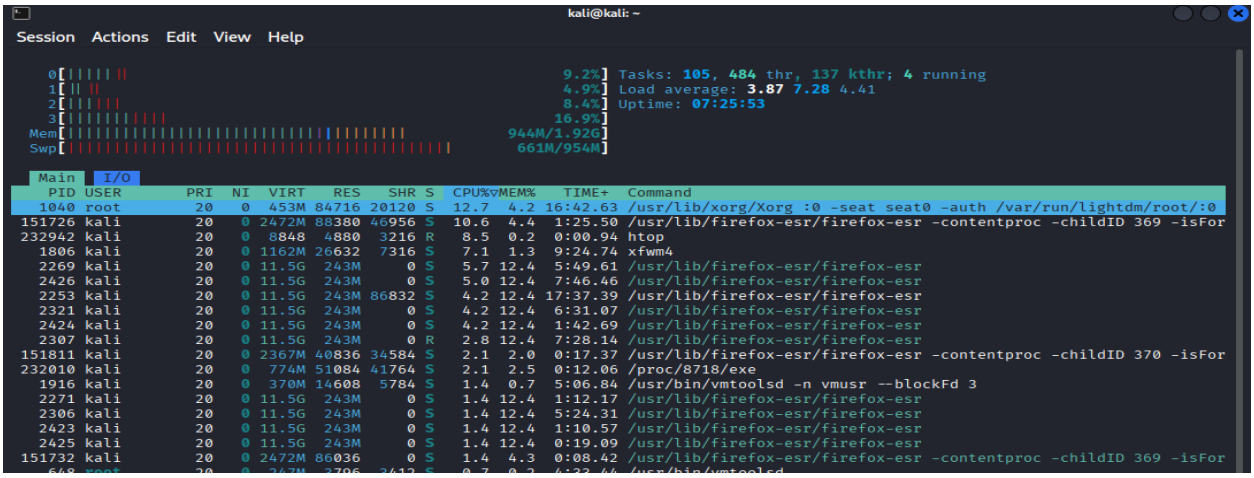
Truy cập vào URL được hiển thị trên terminal.



Kết quả sẽ hiển thị cho chúng ta trang web của Locust.

Đầu tiên, ta sẽ test user 500 và spawn là 1.

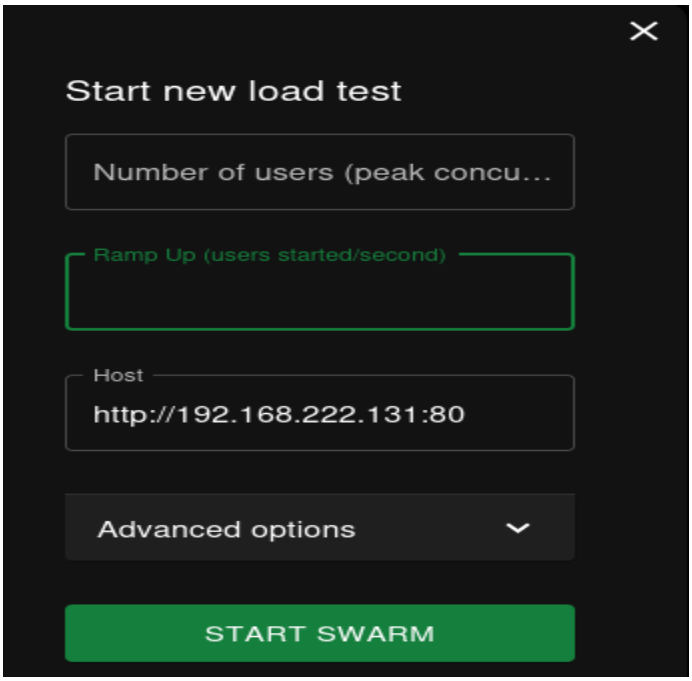
Trước khi start, ta mở một terminal khác và chạy lệnh 'htop' để quan sát CPU và RAM.



CPU	• Core 0: ~10% • Core 1: ~11% • Core 2: ~10% • Core 3: ~15%

	CPU hoàn toàn bình thường
Load average	0.29 2.73 3.22 Giải thích: • 0.29 (1 phút gần nhất) → rất thấp • 2.73 (5 phút) • 3.22 (15 phút) Vì máy có 4 core: • Load < 4 → chưa quá tải • Load > 4 → bắt đầu nghẽn Hiện tại hệ thống không bị quá tải CPU.
RAM	Hiển thị: 973MB / 1.92GB Ram đang dùng ~50%
SWAP	640 MB / 954 MB SWAP cao nhưng RAM chưa đầy, không nguy hiểm lúc này.

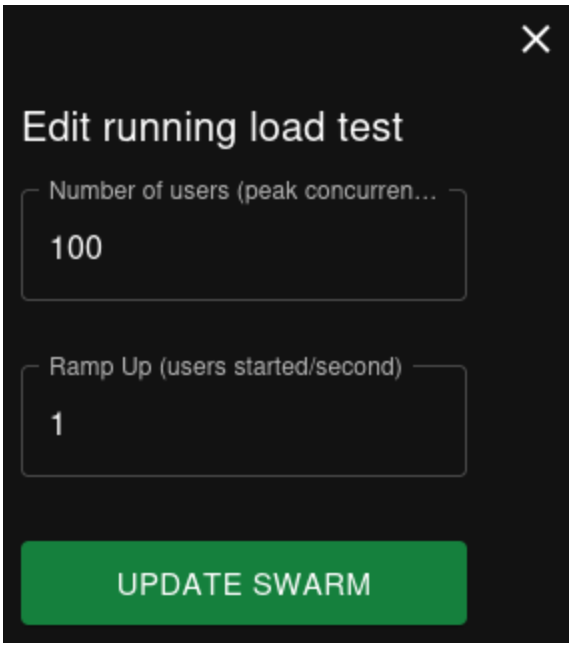
Tiếp theo chúng ta sẽ mô phỏng



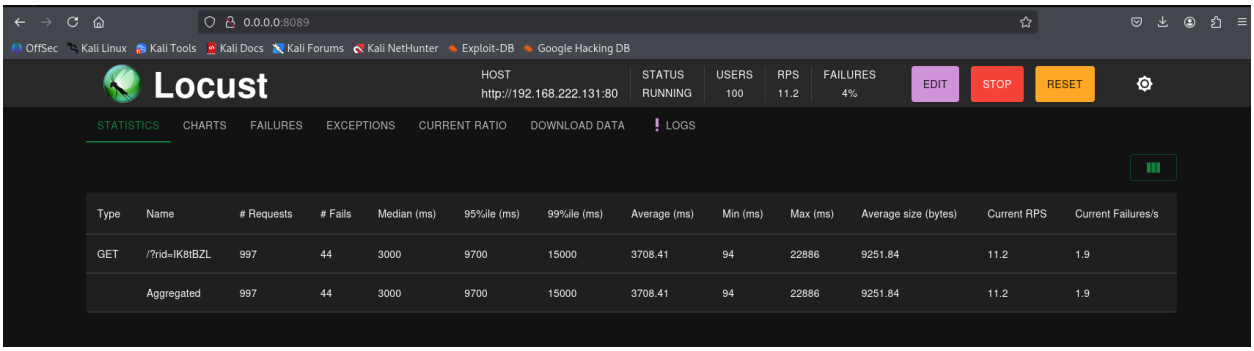
Ô “Number of Users” : tổng số người dùng ảo tối đa mà chúng ta muốn mô phỏng.

Ô “Ramp up”: mỗi giây tạo thêm bao nhiêu user mới.

Đầu tiên ta sẽ thử 100 user và tạo 1 click mỗi giây.



Quan sát htop.



Ta quan sát thấy:

- Fail: 4%
- P95 = 9700ms (9.7 giây)

Hệ thống đang bị degrade rõ ràng.

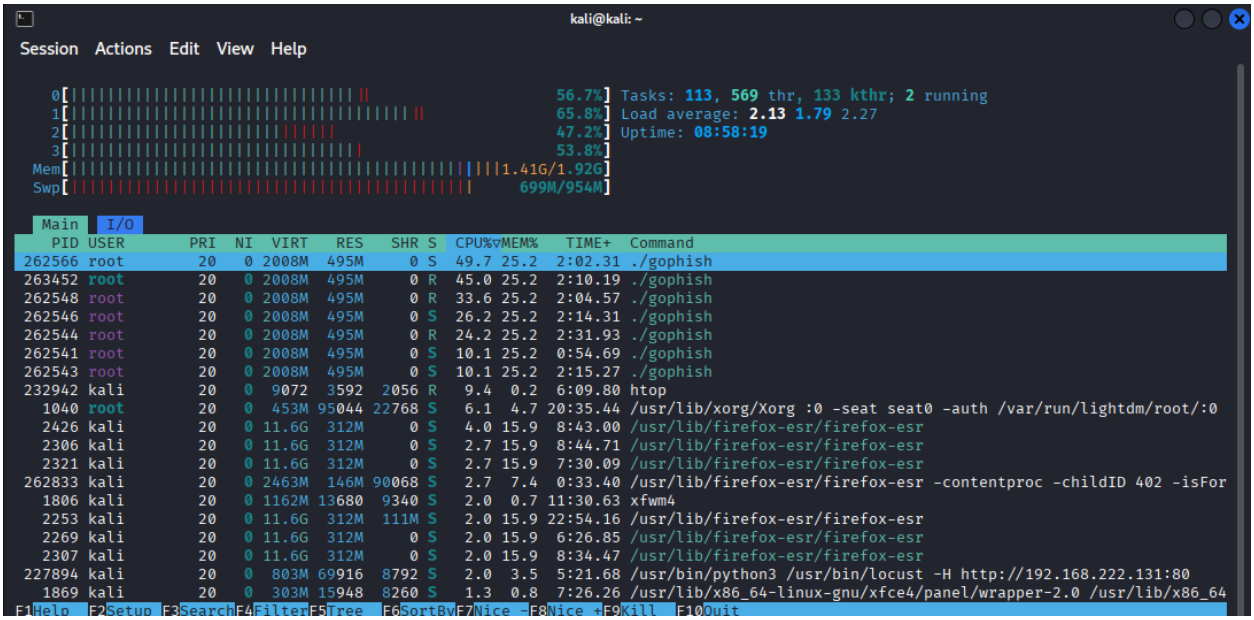
Phân tích độ trễ:
Median = 3000ms

Average = 3708ms

Một request trung bình mất gần 4 giây.

Đây là dấu hiệu request đang chờ tài nguyên.

Tiếp theo ta sẽ quan sát terminal htop:



Khi đạt 100 concurrent users, CPU sử dụng khoảng 50–65%, RAM đạt 73% và swap tăng lên gần 700MB. Gophish sử dụng khoảng 500MB bộ nhớ và nhiều thread xử lý song song. Tuy nhiên, độ trễ tăng mạnh và xuất hiện lỗi do cơ chế khóa ghi của SQLite khi có nhiều thao tác ghi đồng thời, kết hợp với áp lực bộ nhớ làm tăng thời gian phản hồi.

KẾT LUẬN

Ở 100 users:

- Hệ thống vẫn chạy
- Nhưng bắt đầu suy giảm hiệu năng
- Bottleneck chính: SQLite + Memory pressure

GIẢI PHÁP

Chuyển từ SQLite -> PosgreSQL vì:

SQLite:

- Chỉ cho 1 writer tại một thời điểm
- Không phù hợp khi có nhiều request ghi đồng thời

PostgreSQL:

- Hỗ trợ concurrent write tốt
- Có connection pool
- Phù hợp môi trường production

TĂNG RAM

Hiện tại có:

- 2GB RAM
- Swap đang hoạt động

Tăng lên 4GB hoặc 8GB sẽ cải thiện rõ rệt.

Vì:

- Không cần swap
- Giảm disk I/O
- Giảm latency

Để nâng cao khả năng chịu tải, hệ thống nên chuyển từ SQLite sang PostgreSQL nhằm loại bỏ cơ chế khóa ghi đơn luồng. Đồng thời, tăng dung lượng RAM và hạn chế sử dụng swap sẽ giúp giảm độ trễ và cải thiện throughput.